From Oversight to Insight: Transforming Cybersecurity Governance in Boardrooms

Tooba Aamir
Data61
CSIRO
Clayton, VIC, Australia
tooba.aamir@data61.csiro.au

Georgia Psaroulis Dr
Geo-Spir
Perth, Australia
georgia_p@optusnet.com.au

Marthie Grobler
Data61
CSIRO
Melbourne, Victoria, Australia
marthie.grobler@data61.csiro.au

Helge Janicke
Security Research Institute
Edith Cowan University
Perth, Western Australia, Australia
h.janicke@ecu.edu.au

Abstract

Cybersecurity governance is increasingly critical in a digital economy, with board directors playing a central role in shaping organisational resilience. Directors are pivotal in setting cybersecurity strategies and carrying fiduciary obligations that extend to digital risk oversight. This study examines the cybersecurity literacy and governance practices of Australian board directors through a qualitative interview study with 13 participants. Findings reveal a substantial gap in directors' knowledge and confidence, undermining effective oversight and informed decision-making. This deficit limits their ability to interrogate risk reports, challenge assumptions, and steer investment in line with organisational resilience goals. In response, we propose a Board Cyber Governance Model that integrates targeted education, strategic interventions, and structured board–CISO engagement to improve governance capability. By situating cyber governance at the intersection of executive decision-making, risk perception, and digital security, this work contributes to human-computer interaction by highlighting socio-organisational challenges and offering actionable insights for stronger board-level engagement.

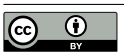
CCS Concepts

• **Human-centered computing**; • **Security and privacy → Usability in security and privacy**; • **Social and professional topics** → Management of computing and information systems;

Keywords

cybersecurity governance, board of directors, cyber literacy, decision-making, organisational resilience, risk management

ACM Reference Format:
Tooba Aamir, Georgia Psaroulis Dr, Marthie Grobler, and Helge Janicke. 2026. From Oversight to Insight: Transforming Cybersecurity Governance in Boardrooms. In *Proceedings of the 2026 CHI Conference on Human Factors in Computing Systems (CHI '26), April 13–17, 2026, Barcelona, Spain.* ACM, New York, NY, USA, 22 pages. https://doi.org/10.1145/3772318.3791142



This work is licensed under a Creative Commons Attribution 4.0 International License.
CHI '26, Barcelona, Spain
© 2026 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-2278-3/26/04
https://doi.org/10.1145/3772318.3791142

1 Introduction

Cybersecurity has evolved from a technical concern to a strategic imperative, now firmly seated at the boardroom table. High-profile incidents have underscored that cyber risk is not merely a matter of IT infrastructure, but a governance challenge with direct implications for organisational accountability and resilience [70]. Despite growing awareness, many board directors still lack the literacy and confidence needed to oversee enterprise-wide cyber risk effectively [21, 44, 45, 62]. In Australia, this gap was spotlighted in the landmark 2022 *ASIC v RI Advice Group* decision, which clarified that boards have a legal duty to ensure adequate cyber risk management[1]. Similar regulatory shifts are unfolding globally, through the General Data Protection Regulation (GDPR) and the NIS2 directive in the European Union, and expanding breach-notification and disclosure regimes in the United States[2], signalling that cyber governance is now a matter of international concern. Recent studies echo these challenges, finding that boards often lack genuine awareness of security issues, despite being formally tasked with all enterprise risks, including cyber [61]. Likewise, CISOs report that they lack decision-making power, and that siloed thinking at the board level continues to misalign current practices within security best practices [34].

This paper explores how board members engage with cybersecurity as a governance issue, drawing on qualitative interviews to surface the practices, challenges and opportunities for improving board-level oversight in a rapidly evolving landscape. Board members in this study are corporate directors (executive or non-executive) who, under the Australian Corporations Act, carry fiduciary duties to act in good faith and with care[3]. The consequences of governance failures are evident from recent incidents, ranging from supply-chain compromises and critical infrastructure disruptions to mass data exfiltrations, both SolarWinds (2020) and Colonial Pipeline (2021) exposed vulnerabilities with global reach, while

[1] https://download.asic.gov.au/media/zhodijpp/22-104mr-2022-fca-496.pdf
[2] https://gdpr-info.eu/; https://digital-strategy.ec.europa.eu/en/policies/nis2-directive; https://www.federalregister.gov/documents/2024/02/12/2024-01667/data-breach-reporting-requirements
[3] https://www.aicd.com.au/board-of-directors

attacks on JBS SA, Optus, Medibank, the Australian Parliamentary Email Network, and Channel Nine highlight the domestic stakes [18].

Our interviews indicate that this expectation is not yet being met. Directors' familiarity with cyber law and standards varies widely, and many struggle to reconcile overlapping regulatory obligations. Smaller firms often prioritise operational survival over compliance, while regulated sectors tend to treat obligations procedurally, reducing them to "tick-box" exercises rather than substantive risk controls. Translating technical metrics into governance decisions remains a persistent challenge.

Approaches to cyber risk management at the board level remain fragmented and inconsistent. While some boards rely on static risk registers, others adopt maturity models and compliance frameworks, or defer to external consultants. Escalation thresholds are often unclear, leaving boards dependent on overstretched IT teams or third-party advisers. These variations create uncertainty in decision-making and hinder the ability to assess and compare organisational cyber posture over time [73]. Although Australia's Notifiable Data Breaches scheme has begun to sharpen director accountability, preparedness and resilience remain uneven across sectors. Incident response is similarly patchy: some boards have developed playbooks and conduct regular simulations, while others remain reactive, improvising communication and decision-making protocols during crises. This ad hoc approach undermines organisational resilience and delays recovery, highlighting the need for structured, board-level routines for cyber incident governance.

In light of these fragmented practices and uneven preparedness, our study examines how board directors conceptualise and govern cyber risk in real-world organisational contexts. The study focuses on surfacing common governance patterns across a diverse set of Australian boards, rather than mapping the full distribution of practices across the economy. We explore the conditions under which governance approaches support more confident decision-making and greater resilience, drawing on qualitative insights to identify patterns that shape effective cyber risk oversight at the executive level. While the empirical focus of this study is Australian, we analyse the findings against widely adopted frameworks (e.g., ISO 27001, NIST CSF) and global regulatory pressures (e.g., GDPR/NIS2), making the implications portable beyond one jurisdiction.

We address three research questions:

- **RQ1 (Governance in practice):** How do boards translate cyber obligations and standards into oversight, i.e., what gets *measured, reported, and decided* at board level?
- **RQ2 (Decision quality and capability):** Which board/director capabilities, information flows, cadence with security leaders, external assurance, and education are associated with *higher-quality cyber decisions*?
- **RQ3 (Incident readiness and resilience):** How are boards prepared to act during major incidents, and which governance practices are linked to *faster recovery and reduced harm*?

These research questions guide our empirical and analytical focus and target governance and decision-making processes rather than the prevalence of practices. RQ1 establishes a descriptive baseline of how boards currently oversee cyber risk; RQ2 identifies the capabilities and practices associated with higher-quality decision-making; and RQ3 examines incident response, readiness and resilience. In this study, we treat *higher-quality decisions* as those that are timely, consequence-aware, evidence-based, and auditable; and *resilience* as the organisation's ability to limit impact and restore critical services following disruption. We use the term *higher-quality decisions* in an analytic rather than normative sense: it describes observable features of decision-making processes rather than a value judgement about the performance or competence of any particular board.

In response, this work makes four contributions to Human Computer Interaction (HCI) and security governance research:

(1) **Empirical characterisation of board-level cyber governance.** This involves providing an exploratory, qualitative account of how cyber risk is understood, surfaced, and acted upon in board settings across a diverse set of Australian organisations, addressing RQ1.
(2) **Factors linked to higher-quality cyber decisions and confident decision-making.** This includes identifying evidence backed themes on board capabilities, information flows, cadence with CISOs, external assurance, and education that correlate with more timely, consequence-aware, and auditable decisions, addressing RQ2.
(3) **Board-level cybersecurity governance during major incidents.** This focuses on identifying patterns in how boards engage with the cybersecurity governance aspects of major organisational incidents before, during, and after major incidents, highlighting role clarity, communication discipline, and recurrent blind spots that hinder resilience, addressing RQ3.
(4) **Proposed Board Cyber Governance Model.** This integrates insights from the findings into a descriptive model that outlines minimum governance capabilities like literacy, decision-useful information flows, structured incident routines, and continuous learning. This model provides a practical scaffold for boards to translate obligations into consequence-aware decisions and strengthen organisational resilience, integrating RQ1, RQ2 and RQ3.

For the rest of the paper, Section 2 positions our study within board-level governance and cross-jurisdictional obligations. Section 3 details the qualitative method, participants, analysis, and trustworthiness. Section 4 reports findings organised by research question. Section 5 introduces the proposed Board Cyber Governance Model that integrates these findings into a set of minimum governance capabilities. Section 6 discusses theoretical, practical, and policy implications and outlines propositions for future testing. Section 7 reflects on validity, limitations, and trustworthiness. Section 8 concludes.

2 Background and Related Work

Boards are now expected to treat cybersecurity as an enterprise-level strategic risk rather than a technical matter delegated entirely to operational teams. In the Australian regulatory context, directors must take reasonable steps to safeguard entities against cyber threats, with regulators setting heightened expectations for oversight [5]. Similar pressures exist globally as organisations navigate

overlapping standards and frameworks, which complicate how directors assess posture and make informed, auditable decisions. This section synthesises the governance landscape, available tools and resources, board composition and role relationships, regulatory disclosure trends, and research on cybersecurity risk management to motivate our study.

2.1 Cybersecurity Governance in Practice

Research on board-level cyber governance is still emerging at the intersection of information systems, corporate governance, and regulatory studies. While directors have long been accountable for enterprise risk, cybersecurity introduces distinctive challenges: technical complexity, fast-changing threat landscapes, and overlapping regulatory obligations across jurisdictions. Research also shows that leaders with predominantly non-technical backgrounds exert significant influence over cybersecurity policy and governance, shaping priorities, interpretations of risk, and the degree of organisational engagement with security practices [46, 60, 67, 75, 82, 83]. Much of the literature focuses on prescriptive frameworks or survey-based insights, leaving limited empirical understanding of how directors actually translate obligations into boardroom practice. This section reviews five strands of related work: (i) cyber risk as a board-level governance problem, (ii) governance toolkits and dashboards, (iii) board composition and the CISO relationship, (iv) disclosure and accountability trends, and (v) cybersecurity and risk management research.

Cyber Risk as a Board-Level Governance Problem

High-profile incidents have placed cybersecurity firmly in the boardroom [70], with stakeholders actively critiquing the board of directors' quality by how it manages cyber risk and the amount of cybersecurity information disclosed [73]. The board of directors and its committees, such as the audit committee and the risk management committee, are crucial corporate governance players in corporate risk management [73], yet many boards struggle to reconcile compliance-driven reporting with decision-useful oversight. Boards increasingly adopt sense-making routines, including environmental scanning, interpretation, and action in their oversight of cyber threats [31]. Reports are often overly technical, inconsistently formatted, or misaligned with business objectives, making it difficult for directors to fulfil their duties effectively [7, 72]. This translation problem, i.e., bridging technical posture and strategic choice, is not unique to Australia but reflects a wider shift recognising cyber as a core business risk requiring integration into enterprise strategy [70].

Governance Toolkits and Dashboards

A growing ecosystem seeks to support boards with practical guidance and situational awareness. Publicly available resources include the UK's *Cyber Security Toolkit for Boards* [53] and *Leadership and Governance Pack* [52]; the US's *Shields Up* initiative [23]; Canada's *Cyber Security Guidance for Heightened Threat Levels* [16]; and Australian materials such as ASIC's *Key Questions for an Organisation's Board of Directors* [6] and guidance from peak bodies like the Australian Institute of Company Directors [58, 59]. These initiatives build on earlier recognition of the board's role in cyber risk oversight [51] and are complemented by work on the behavioural effects of security communication and training [68]. Commercial offerings, such as PwC's *Board Central* [65] and Gartner's board-level resources [29], aim to provide dashboards, benchmarking, and curated guidance, while risk-quantification approaches target capital-allocation decisions and board comprehension of exposure [15]. Despite their potential benefits, adoption remains inconsistent, customisation is often necessary, and many tools risk reducing board oversight to a mere compliance "tick-box" exercise. Table 1 shows an overview of the regulatory landscape in terms of board duties and decisions.

Board Composition and the CISO Relationship

Board structure differs by jurisdiction and has an impact on board effectiveness [73]. In Australia and the UK, directors are predominantly drawn from business backgrounds [49] with strong regulatory oversight traditions in the UK [77]; US boards typically include a higher proportion of independent directors [63]; and Germany's two-tier system separates supervisory and management functions to balance stakeholder interests [35]. Across these structures, the board–CISO relationship is consistently pivotal. Studies emphasise the centrality of the CISO role to enterprise risk governance [71] and identify governance roles and responsibilities that enable constructive challenge and clear accountability [24, 56]. Research further links IT-savvy directors and risk-based partnership with improved decision-making [39, 48]. In practice, when boards lack cyber-literate directors, they often depend on CISOs to translate technical risk into consequence-forward, board-ready narratives [2]. However, recent studies reveal constraints on the CISO role, noting that limited organisational authority and reliance on narrow communication artefacts, such as awareness training or phishing simulations, restrict their ability to convey security issues effectively [34]. In the Australian context, this challenge is compounded by the absence of practical, board-level frameworks for cybersecurity governance [30].

Disclosure and Accountability Trends

Regulatory disclosure laws and standards are sharpening expectations that boards actively oversee cyber risk. In the US, the Securities and Exchange Commission (SEC)'s final rules (effective December 2023)[4] require public companies to disclose material cyber incidents and describe risk management and governance [26, 41]. In addition, disclosure studies show that boards are increasing transparency of cyber and AI oversight, pointing to evolving governance norms [54]. Such laws and standards push boards to improve governance, work more closely with security leaders, and get better information. Similar pressures are emerging globally. In the UK, the Financial Conduct Authority has increased scrutiny of cyber governance in financial services, while Singapore's Cybersecurity Act mandates reporting and risk management for critical information infrastructure. Similar requirements are imposed in Australia's Security of Critical Infrastructure Act 2018 (SOCI), which mandates an All-Hazards approach to risk management that includes cybersecurity. Academic research further highlights how disclosure

[4] https://www.sec.gov/files/rules/final/2023/33-11216.pdf

Table 1: Overview of key frameworks and standards.

Laws & standards	Scope	Board's duties / Decision points
GDPR (EU/UK)	Personal data	Breach reporting (72h), accountability; link privacy risk to business impact
NIS2 (EU)	Essential entities	Board approval, training, liability; supply-chain risk visibility
SEC (US)	Public companies	Incident/materiality disclosure; board governance reporting
Privacy Act (AU)	Australian entities	"Reasonable steps" for security; notifiable data breaches
CPS 234 (AU)	APRA-regulated	Board accountable for security capability; notify APRA within 72h
ISO 27001	Global (certifiable)	ISMS governance, leadership, risk-based controls; certification evidence
NIST CSF	Voluntary	Posture narrative; prioritised roadmap; resilience metrics

expectations influence board behaviour, with organisations increasing cybersecurity risk disclosures following severe data breaches, driven by both ethical obligations and market expectations [19]. However, regulatory volatility can also introduce strategic uncertainty, prompting delayed investments and inconsistent governance practices [20]. Studies show that boards often struggle to navigate evolving legal frameworks, underscoring the need for clearer guidance and stronger governance mechanisms [69].

Cybersecurity and Risk Management Research

A substantial body of literature frames cybersecurity as an enterprise risk that must be integrated into strategy and aligned with regulatory and control frameworks [4, 22]. Literature reviews indicate that, although numerous metrics exist, board-usable decision-support models remain rare [50]. Work on board capability consistently calls for tailored educational programmes and sustained upskilling for directors [13, 32, 36, 79]. Parallel streams examine structured decision-making, foresight and scenario planning, usability of risk artefacts, and data-driven governance as enablers of proactive oversight [40, 42, 50, 55, 57]. Prior work has also shown how CISOs navigate competing pressures between compliance, technical assurance, and business enablement, underscoring that governance involves constant trade-offs rather than static adherence to frameworks [80]. Recent HCI work also highlights the value of inclusive, bottom-up mechanisms for surfacing employee perspectives on cybersecurity, for example through anonymous discussion platforms that foster candid dialogue about policies and practices [37]. While maturity models are widely referenced for assessment and communication [47], their limitations for board decision-making have been noted; economic perspectives similarly caution that optimal security investment depends on risk, incentives, and information quality [17].

Beyond current frameworks, recent research highlights the nuanced socio-organisational dynamics of cyber governance. CISOs frequently navigate difficult trade-offs between enabling business innovation and enforcing compliance. This balancing act can result in fragmented security practices or reduced visibility, particularly as security responsibilities shift toward development and product teams, giving rise to "shadow security" workarounds. Cultivating an organisational cybersecurity culture is central to risk resilience. Strong culture initiatives, driven by leadership commitment, tailored training, and top-down support, are critical; yet, most frameworks rely on surveys or static models. More dynamic, empirically tested tools, however, remain rare [3, 76]. Meanwhile, evidence shows that boards often overestimate their cybersecurity preparedness and overlook their own vulnerabilities [38]. Many directors lack formal cyber training and are not integrated into organisational incident preparedness, underscoring the need for tailored educational programs such as tabletop exercises, phishing simulations, and one-on-one guidance [25, 66]. Recent work has also examined how boards engage with cybersecurity risk, documenting challenges such as information asymmetries, limited technical confidence among directors, and a tendency to rely on high-level budget decisions rather than structured oversight [61]. These studies highlight common difficulties in interpreting technical material, scrutinising management assurances, and aligning cyber risk with broader governance responsibilities. Such findings add to the emerging empirical picture of how directors navigate cyber-related decision-making within board environments.

Taken together, prior research shows persistent challenges in how cybersecurity information is produced, translated, and used within organisations. Much of the literature focuses on board–CISO engagement or high-level risk decision-making, with comparatively little attention to the governance routines and information structures that enable directors to exercise effective oversight. Our study extends this work by examining the structural and procedural conditions that support or hinder consequence-aware cyber governance, including pre-agreed thresholds, playbook familiarity, and outcome-oriented metrics. By analysing directors' lived practices, we highlight how these routines collectively shape oversight quality and create the foundations for a more integrated understanding of board-level cyber governance, which we develop in later sections.

2.2 Synthesis and Gap

Board directors must navigate a complex landscape of overlapping regulatory obligations, limited cybersecurity literacy, and inconsistent adoption of governance tools. Across public toolkits, commercial dashboards, diverse board structures, and evolving disclosure regimes, a persistent gap remains: boards often lack *decision-useful* information flows and structured governance routines to support timely, evidence-based, consequence-aware decision-making.

As illustrated in Figure 1, insights from the reviewed literature can be organised into a board-level cyber governance cycle. Regulatory obligations and sectoral standards establish the baseline expectations that boards must oversee, but these are filtered through each organisation's context, including its business model, critical assets,

and supply-chain dependencies. The middle stages illustrate how these obligations and contexts are translated into board-usable artefacts, that is plain-language CISO briefings, consequence-oriented Key Performance Indicators (KPIs), quantified scenarios, and assurance reports, which in turn are shaped by governance routines such as board–CISO cadence, independent challenge, and director education. These routines condition the quality of board decisions on investment, risk acceptance, third-party oversight, and disclosure. Outcomes are expressed in terms of resilience, continuity, compliance, and stakeholder trust. Crucially, the bottom feedback loop emphasises that incidents and lessons learned should feed back into governance processes, reinforcing a cycle of continuous improvement.

This synthesis highlights a gap. While many resources aim to support directors, most remain compliance-oriented and fragmented, offering little guidance on the *minimum viable governance routines* required for credible cyber oversight. Existing work tends to examine individual elements of cybersecurity governance (such as disclosure, board–CISO relationships, or risk reporting) without examining how these elements are enacted together in board-level practice. Our interviews suggest that this fragmentation is mirrored in practice: boards often adopt individual tools or routines in isolation, rather than as part of an integrated governance approach. Addressing this gap, our study empirically examines how board-level cybersecurity governance is enacted in situ and synthesises observed practices into a Board Cyber Governance Model. Rather than proposing a prescriptive framework, the model serves as an integrative, descriptive scaffold that brings together regulatory obligations, board-usable artefacts, and governance routines as they are variably combined in practice. The model directly reflects the three research questions outlined in Section 1, linking what boards measure and decide (RQ1), the conditions that support higher-quality decisions (RQ2), and the routines that underpin incident readiness and resilience (RQ3).

3 Methodology

To investigate how board directors engage with cybersecurity governance, we adopted a qualitative research design guided by interpretivist principles, with attention to context, trustworthiness, and ethical rigour across all stages of the study, from participant recruitment to data collection, analysis, and reflection on limitations and transferability.

3.1 Design and Stance

To explore how board directors govern cybersecurity in practice, we employed a qualitative, interpretivist research design centred on semi-structured, problem-focused interviews with directors and senior executives (refer to Appendix A.1). The 'problems' guiding this study were derived from persistent challenges reported in the literature and industry reports, including directors' limited cyber literacy, inconsistent board–CISO engagement, and fragmented incident governance. As detailed in Sections 1 and 2, these problems informed our research questions and served as thematic anchors during data collection. Our problem-centred interview approach invited participants to reflect on these challenges through their own experiences, while remaining open to the emergence of new or contradictory perspectives.

We formulated four *provisional* propositions from the literature synthesis in Section 2 and mapped to our research questions (refer to Section 1) as sensitising concepts rather than hypotheses. These propositions informed our interview prompts and early coding, but were revisited reflexively and adjusted in response to participant narratives. This approach allowed prior framing to guide exploration without constraining interpretation, consistent with our interpretivist stance. Participants responded to these prompts through self-assessment, under ethical clearance, without disclosing sensitive organisational details.

- **P1 (mapped to RQ1):** Directors' knowledge of legislation, regulations, and control frameworks varies with experience and background.
- **P2 (mapped to RQ1/RQ2):** Preferred risk-management strategies reflect perceived risk and organisational priorities.
- **P3 (mapped to RQ3):** Prior events, available resources, and existing frameworks shape perceived incident capability.
- **P4 (mapped to RQ2/RQ3):** Active board engagement in education, governance, and decision processes fosters a stronger resilience posture.

In line with reflexive thematic analysis, these propositions were used as sensitising concepts, not evaluative benchmarks. They supported early coding by highlighting areas of potential interest but were adapted, qualified, or set aside where participant accounts diverged. This ensured that meaning-making was led by participant interpretation rather than by the propositions themselves. This approach enabled us to capture nuanced perspectives on decision-making, governance conditions, and incident response. While the study is situated in the Australian regulatory and organisational context, we interpret the findings in relation to international frameworks and obligations to support broader relevance and analytical transferability.

To capture both strategic and practical perspectives, we combined *theory-generating expert interviews* [11] with *problem-centred interviews (PCI)* [27]. Figure 2 illustrates the combined approach used to elicit how researchers and board directors work together to develop a problem-centred reconstruction of the issue, using semi-structured prompts, open-ended discussion and clarifying questions, to support the consistent capture of directors' experiences and governance practices. [11, 27, 64, 78]. Consistent with PCI, the 'problems' referenced in this study were not treated as predetermined categories but as provisional starting points derived from the literature (e.g., information asymmetries, low cyber literacy, inconsistent incident governance). As reflected in the interview guide (Appendix A.1), prompts were framed broadly (such as asking what information directors found decision-useful, how cyber risks were understood, or when the board became involved during incidents) without specifying what the underlying issue should be. Participants were free to redefine, contest, or introduce issues based on their own governance experience, and several redirected discussion beyond the initial prompt structure. In this way, the characterisation of governance problems emerged from participants' meaning-making rather than researcher imposition, aligning with reflexive thematic analysis's emphasis on co-constructed interpretation. Two

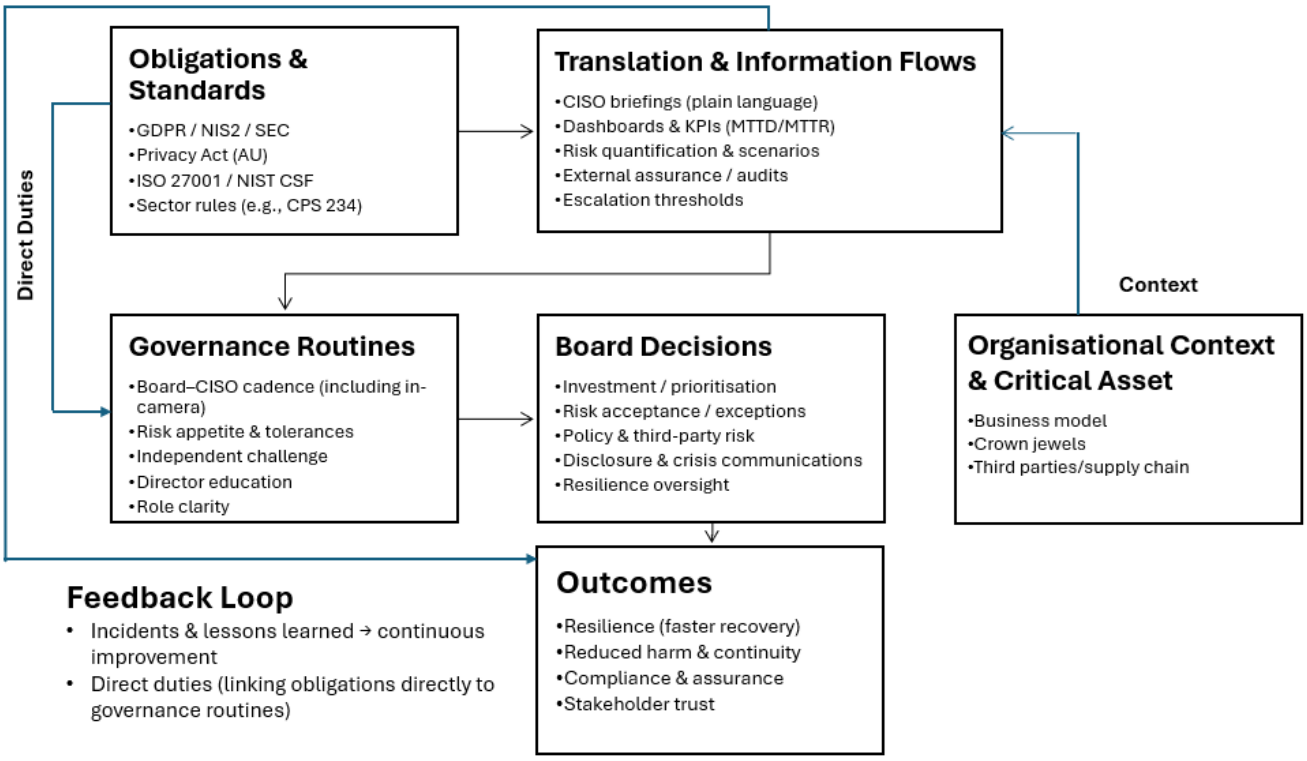


Figure 1: Board-level cyber governance concept map

project team members, both with cybersecurity and governance expertise, with one additionally a board-governance practitioner with Australian Institute of Company Directors (AICD)[5] training, facilitated each interview to balance discussion and reduce interviewer bias; sessions were video-recorded to maximise accuracy of capture and enable careful review [27, 81].

3.2 Participants and Recruitment

We interviewed directors and senior executives from n=13 organisations spanning multiple sectors and sizes. All participants currently held, or had held within the prior five years, a board-level role, providing contemporary perspectives on governance practices. In Australia, a director is a legally appointed board member with statutory duties under the Corporations Act (e.g. to act honestly and in good faith) [1]. Although the sample size of n=13 may appear small, qualitative research indicates that 90% of thematic patterns typically emerge within 12–13 interviews when participants represent a focused expert group [28, 33]. Table 2 summarises domains, organisational size (OECD categories: small 10–49; medium 50–249; large 250+ employees[6], and director role).

Between March and November 2023, we recruited board directors and senior executives through professional networks and sector-specific contacts. Recognising the well-documented challenges of accessing senior participants, including non-response and limited availability, we aimed to mitigate selection bias by ensuring diversity across organisational sectors and sizes. Participants serving on multiple boards were asked to reflect on a single board to maintain consistency. Interviews were conducted online via Webex[7] or Microsoft Teams[8], with one participant and two facilitators present in each session. Each interview lasted between 45 and 60 minutes and was recorded with consent for subsequent transcription and analysis [27, 81].

3.3 Data Collection

The semi-structured guide (Appendix A.1) covered five qualitative themes that reflect our research questions:

- Cybersecurity risks, threats, and their connection to director literacy;
- Organisational cybersecurity strategies in practice;
- Board expertise, expectations, and alignment with reality;
- Incident management at board level (roles, timing, communication);
- Cyber resilience as an element of organisational strategy.

During the interview, participants often referred to real events to explain impacts and decisions. The depth of the sessions produced comparable narratives, and recurring patterns across interviews

[5]https://www.aicd.com.au/
[6]https://www.oecd.org/en/data/indicators/enterprises-by-business-size.html
[7]https://www.webex.com/suite/meetings.html
[8]https://www.microsoft.com/en-us/microsoft-teams/group-chat-software

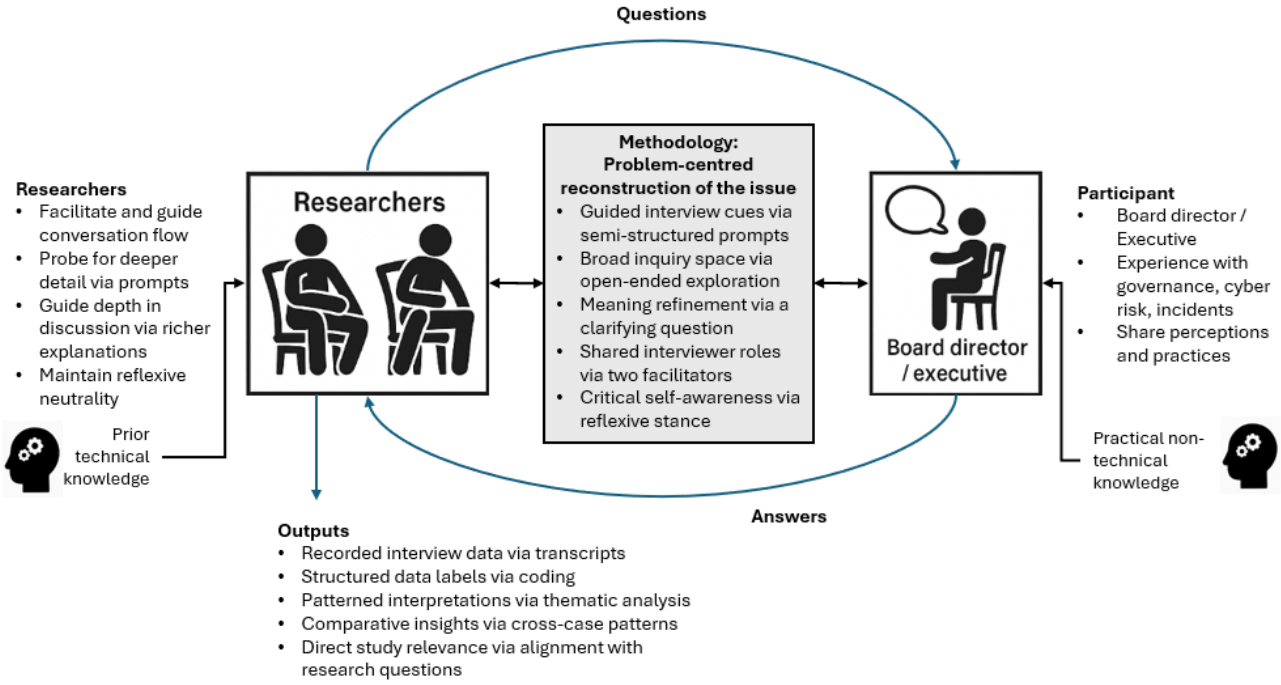


Figure 2: Overview of the interview approach combining theory-generating expert interviews [11] and problem-centred interviews (PCI) [27]

Table 2: Participant Overview

Participant ID	Domain(s)	Organisation Size	Director Role
P001	Higher Education	Small	Executive
P002	Government and Industry	Medium to Large	Non-executive
P003	Public Trading	Large	Executive
P004	Tech Startup	Small	Non-executive
P005	General Industry	Medium	Executive
P006	General Industry	Medium to Large	Non-executive
P007	Financial Services	Large	Executive
P008	Academia and Financial	Large	Executive
P009	General Industry	Medium	Executive
P010	Education	Medium	Executive
P011	Startup	Small	Executive
P012	General Industry	Medium	Non-executive
P013	IT Services and Consulting	Large	Executive

indicated that n=13 was sufficient for thematic saturation in this context.

3.4 Analysis

Our analysis combined reflexive thematic analysis with computational support to organise and interrogate the corpus. Following reflexive thematic analysis, inter-coder agreement was used solely as a prompt for dialogue and shared meaning-making, not as a measure of objectivity. Following the approach for comparable studies [8, 22, 43], we:

(1) **Prepared data:** removed interviewer prompts and non-verbal markers; anonymised transcripts.
(2) **Parsed text:** tokenised with Python/NLTK [9] to enable efficient retrieval and memoing.
(3) **Developed a coding scheme:** iteratively built a codebook (refer to Appendix A.2) aligned with research questions and sensitising propositions; we used Latent Dirichlet Allocation (LDA) [10] as a topic-modelling triangulation to surface candidate clusters that informed (but did not determine) codes.
(4) **Manual coding and theme generation:** Two researchers, both with cybersecurity/governance, HCI and qualitative

analysis expertise, coded a subset of transcripts and developed a shared codebook, refined iteratively in relation to the research questions and propositions. The initial double-coded subset consisted of two transcripts and approximately thirty primary codes, selected to capture variation in organisational size and sector exposure. Cohen's κ was calculated on the initial double-coded subset as a calibration step, yielding an approximate value of $\kappa = 0.68$. In line with reflexive thematic analysis, this statistic was used only as a heuristic to identify divergent interpretations rather than as a measure of reliability [12, 14]. Discrepancies were resolved through discussion-based sense-making, consistent with the reflexive emphasis on shared interpretation instead of coder uniformity. This approach aligns with contemporary guidance that reflexive thematic analysis prioritises interpretive depth over inter-coder convergence [12, 14].

(5) **Iterative refinement and synthesis:** We maintained an audit trail of code changes and analytic memos, repeatedly linking excerpts to RQs (see Section 1) and drafting within-case and cross-case summaries.

This hybrid approach lets us leverage computational affordances (for recall and breadth) while keeping interpretation grounded in human judgment. This is appropriate for our interpretivist stance. An explicit audit trail of code changes and reflexive memos was maintained throughout (see Appendix A.3).

3.5 Trustworthiness and Ethics

We enhanced credibility and dependability via analyst triangulation (two facilitators; two coders), memoing throughout analysis, and an explicit audit trail of codebook versions and decisions (see Appendix A.3 for examples). To support reflexive rigour, researchers engaged in memoing throughout the study to surface their own assumptions, such as expectations about board-level metrics, and actively identified disconfirming evidence during analysis. Diverging interpretations were discussed collaboratively, allowing positionality to inform rather than bias the findings. Participants gave informed consent after being told the objectives and risks, and could withdraw at any time without consequence. We focused on professional experiences rather than identifiable organisational details to minimise sensitivity. Personal identifiers were removed; recordings and transcripts were stored on access-controlled devices available only to a small subset of researchers. Data handling complied with the Australian Privacy Principles and GDPR, allowing participants the opportunity to review anonymised transcripts, if requested. No financial compensation was provided. *Ethical approval was obtained from the relevant institutional review board.*

As is common in studies involving senior-level participants, our sample size is modest and geographically concentrated, with potential skews in sector representation and participant seniority. These limitations are mitigated by the diversity of organisational sectors included, the multi-board experience of several participants, and the alignment of findings with internationally recognised governance frameworks such as ISO 27001, NIST Cybersecurity Framework, and global breach-notification regulations, which supports the analytical transferability of observed patterns beyond the Australian context.

4 Findings

This section presents the study's findings structured around the three research questions (RQ1-RQ3) (refer to Section 1), based on qualitative data obtained from participant interviews (P001-P013). Illustrative quotes and frequency indicators are included where they enhance clarity or support interpretation. Comprehensive coding summaries and extended tables are provided in the Appendix.

4.1 RQ1 — Governing in practice

Boards enact cyber governance by converting regulatory obligations and standards into structured oversight activities. This subsection explores how cyber risk is monitored and managed at board level, including the metrics used, reporting mechanisms adopted, and decision-making processes employed, linking to RQ1.

Routine cyber governance inputs. Across our interviews, directors described a fairly consistent set of items that appear in board packs each cycle: posture snapshots (often in traffic-light form), views of high-risk assets or "crown jewels", assessments of third-party and supply-chain exposure, notable incidents and trend lines, and logs of compliance exceptions. Many boards also receive quarterly assurance updates (internal audit or external reviews) and short notes on regulatory change. However, several directors emphasised that colour-coded dashboards alone are inadequate. The information presented must be meaningfully interpreted and linked to the specific decisions the board is required to make. As one director put it:

> *"We can read the traffic lights, but we need to understand what they mean for the business next quarter."* (P009)

From interview recollections, posture snapshots were mentioned by 10 of 13 participants; incident trend lines by nine participants; third-party exposure by eight participants; and compliance or exception logs by seven participants. Where external assurance was routine, directors reported greater confidence in challenging management perspectives and calibrating the organisation's risk appetite. However, they expressed a need for reporting that goes beyond surface-level indicators, linking technical posture to business impact, defining clear escalation thresholds, and identifying emerging risks rather than reiterating static compliance metrics.

What boards know about laws, regulations, and controls. Directors' literacy clustered around privacy and breach-notification duties, plus a handful of well-known frameworks. In our interviews, the *Privacy Act 1988* was cited by seven participants (P001, P002, P005, P006, P007, P008, P013); the *Notifiable Data Breaches* scheme by four participants (P002, P006, P007, P013); the APRA prudential standard CPS 234 by three participants (P002, P005, P006); the *Security of Critical Infrastructure Act* by three participants (P002, P006, P007); and the *GDPR* was cited by four participants (P005, P007, P008, P013), including one director serving on a multinational board (P008). ISO 27001 and the NIST CSF were each named by three directors, mostly representative of larger or internationally exposed organisations. Smaller entities tended to focus on core business and minimum compliance, with less systematic attention to control frameworks beyond policy templates and audits. Directors also highlighted how hard it is to navigate overlapping requirements:

> *"How do boards and companies navigate this plethora of Acts, framework schemes… Which one is federal, which is company level, which is state? All different."* (P006)

How choices are framed. Investment and risk-acceptance proposals were most often presented against the stated appetite and impact trade-offs (availability vs. confidentiality, service continuity vs. data protection), with external assurance used as a confidence anchor. Across interviews, scepticism was voiced about using *maturity scores* as a proxy for decision quality. Directors preferred outcome-oriented KPIs that connect directly to business consequences, such as mean time to detect, contain, or restore crown-jewel services, over laddered levels that are easy to communicate but difficult to tie to outcomes. This tension also showed up in compliance versus resilience debates:

> *"More compliance does not equal less risk… It becomes a tick-boxing exercise for assurance rather than real reduction."* (P004)

Directors warned that maturity ratings can be misleading, making them a blunt instrument for board decision-making. What they valued were measures that clearly demonstrate resilience in practice:

> *"Maturity scores can be gamed; directors really want consequence-forward measures — things like mean-time-to-detect [MTTD], mean-time-to-restore [MTTR], or whether we met the service SLA after an incident. That tells us if the business is actually resilient, not just that we ticked boxes."* (P006)

In short, directors showed more comfort with consequence-forward metrics (MTTD, MTTR, restoration-to-SLA) than with abstract maturity ratings. These measures give a clearer line of sight to business impact and accountability.

Table 3 summarises typical board-pack items and the decisions they are meant to inform.

In summary, boards consistently review posture, incidents, and third-party exposure. Decision quality improves when reporting is consequence-forward and independently challenged; relying on maturity levels alone can obscure the trade-offs that matter most for resilience.

4.2 RQ2 — Decision quality and capability

The quality of cyber-related decisions at board level is shaped by a combination of director competencies, the quality and cadence of information exchange, engagement with security leaders, and the presence of external assurance. Interviews linked higher-quality decisions, that is, decisions that are timely, evidence-based, consequence-aware, and auditable, to three areas: board capabilities and composition; the nature and flow of information and cadence; and the strategic approaches boards adopt to govern cyber risk. Together, these factors underpin more effective and informed cyber governance.

Capabilities and composition. Boards that included at least one member with prior technical or cyber exposure, combined with a culture of *constructive challenge*, reported more probing questioning and faster decision-making on breach-response investments. Regular *in-camera* access to the CISO, beyond formal sessions, was seen as enabling candid discussions of risks and clearer lines of accountability. As one director put it:

> *"We don't need everyone to be a cyber expert, but we do need someone who can ask the second-order questions."* (P008)

Others stressed the role of independent assurance in countering over-reliance on management accounts:

> *"External assurance keeps us honest… it helps the board push back and ask: are we resilient, or are we just compliant?"* (P013)

Information and cadence. Directors highlighted the value of plain-language reporting anchored to a small set of consequence-forward KPIs, such as time to restore crown-jewel services to SLA, or the proportion of incidents contained within defined thresholds. They emphasised the importance of clearly stated escalation points: when the board must be informed and what decisions are expected. This ensures that metrics function as actionable decision triggers, rather than static indicators of compliance. One director captured it directly:

> *"Show me what changes if this KPI goes red next month. What decision do we need to make?"* (P007)

Quarterly scenario walkthroughs and tabletop exercises were described as useful for rehearsing thresholds and clarifying roles. Independent assurance, whether through internal audit or red-team briefings, sharpened questions and helped move the discussion from compliance to consequence. Directors preferred dashboards stripped of jargon and concise, context-specific briefings over lengthy, generic sessions. As one participant observed:

> *"Dashboards have to tell me what matters for this business, not just cyber jargon—keep it short, keep it in context."* (P005)

Strategy preferences. Approaches varied. Four participants (P001, P005, P006, P008) emphasised risk registers with explicit board involvement, though some questioned whether the ratings reflected real exposure. Five participants (P002, P006, P007, P008, P013) leaned on maturity frameworks and external verification, particularly in regulated sectors, but warned against over-weighting laddered scores without outcome KPIs. One director remarked:

> *"Maturity scores can be gamed; what matters is whether we can restore to SLA when something breaks."* (P006)

Three participants (P003, P006, P007) highlighted vulnerability management as a first-order discipline tied to patch hygiene and exception control:

> *"You can't talk resilience if you haven't even patched the basics."* (P007)

Compliance-based approaches were noted by four participants (P004, P007, P008, P011) to satisfy stakeholder assurance. Another four participants (P001, P003, P006, P010) favoured metrics-driven strategies, particularly in education, for accountability and to avoid a tick-box mentality. Three participants (P005, P006, P009) described integrated strategies that embed cyber into enterprise risk and resilience, with periodic control testing and rehearsals.

In summary, high-quality cyber decision-making at board level can be enabled by a combination of director expertise, meaningful information flows, and strategic governance practices that link technical risk to business impact. Table 4 consolidates these observations and provides brief, practice-oriented examples from the interviews to illustrate how each condition manifested in the data and how the attributes of higher-quality decisions identified in Section 1, i.e., timeliness, consequence-awareness, evidence use, and auditability, were expressed in board practice. These indicators

Table 3: Board-level cyber pack: items, purpose, cadence, and the decision it informs

Item	Purpose	Cadence	Decision it informs
Posture snapshot (heatmap/traffic lights)	Exposure and trend at a glance	Quarterly	Budget prioritisation; risk acceptance/deferral
High-risk assets ("crown jewels")	Where failure hurts most	Quarterly	Control prioritisation; tolerances; oversight focus
Third-party/supply-chain exposure	Concentration risks; critical vendors	Quarterly/ad hoc	Contractual requirements; due diligence; risk transfer
Incident trend lines/notable events	Frequency, severity, learning themes	Quarterly/after-action	Policy changes; detection/response investments
Compliance status/exceptions	Regulatory posture; waivers	Quarterly	Exception sign-off; escalation triggers
External assurance (audit/red team)	Independent challenge	Semi-annual/annual	Appetite calibration; follow-ups to management
Regulatory change/disclosure cues	Emerging duties; thresholds	As required	Reporting posture; stakeholder communications

are analytic rather than normative, reflecting observable features of decision processes rather than judgments about individual boards.

4.3 RQ3 — Incident readiness and resilience

Board preparedness for major cyber incidents is underpinned by governance practices that enable swift response and recovery. This subsection investigates how boards mobilise during cyber crises and highlights the governance features associated with reduced impact and accelerated restoration. While many organisations use all-hazards crisis frameworks, our focus in RQ3 is specifically on the cybersecurity aspects of incident governance, even where these are embedded within broader enterprise processes. Participants pointed to three ingredients for readiness: clarity on roles and timing of board involvement; disciplined communication during response; and learning loops that bring after-action insights back to the board with follow-through.

Role clarity and timing. Directors emphasised the importance of early notification and clearly defined decision rights, with board involvement scaling according to the severity of the incident. They described specific thresholds for informing the board, such as customer data exfiltration or multi-day service outages, and stressed the need for clarity on who is responsible for key decisions during a crisis, including risk acceptance for degraded operations and the timing of external disclosures. One director's advice was direct:

> *"Get the board in the loop early for major incidents—don't make us find out from the media."* (P010)

Another director stressed that escalation should be tied to consequences, not formality:

> *"If customer data is at risk, that's not management's call alone—the board needs to own that trade-off."* (P007)

Communication discipline. Directors stressed the need for scripted updates, time-boxed briefings, and a designated spokesperson to minimise confusion and protect the organisation's reputation. Coordination with regulators and external stakeholders should be pre-planned, with legal counsel involved to shape disclosure wording and timing. As one noted,

> *"The worst outcome is mixed messages … one voice, one timeline, that's how you preserve trust."* (P012)

Several directors also emphasised the importance of documenting board awareness during response, both for accountability and to demonstrate active oversight.

Learning loops. Directors advised that post-incident reviews should consistently return to the board with concrete lessons learned, targeted investments, and relevant policy updates. These feedback loops help shape future board reporting, for example, adding a restoration-time KPI for crown-jewel services or introducing segmentation controls after a supplier-originated breach, ensuring that oversight evolves in response to real-world events. One director put it plainly:

> *"If the board doesn't see the lessons, it's just an IT drill—we need to see how resilience improves."* (P009)

Observed variation. Some boards debated whether the chair or CEO should be the public face in a major incident. Three participants (P010, P012, P013) argued that the deciding factor is not the title but the capability under scrutiny:

> *"It's not about who sits where on the org chart—it's who can stand up to the cameras when the pressure is on."* (P013)

Across accounts, incident governance depended on clear thresholds, disciplined communication, structured learning cycles, and pragmatic choices of spokesperson to preserve legitimacy during crises.

In summary, where role clarity, scripted briefings, and after-action loops existed in practice, recovery was faster and harm reduced. Without these capabilities, duplication, delay, and reputational damage were more likely to be present and hinder the organisation's incident readiness and resilience.

4.4 Synthesis of findings

Across the interviews, three patterns stood out. First, directors found it difficult to translate technical and compliance-driven material into decision-useful oversight. Reliance on colour-coded dashboards without business consequence links, and scepticism toward

Table 4: Observed conditions, strategy preferences, and indicative decision-quality signals

Condition or practice observed	Indicative signals of higher-quality decisions
At least one cyber/tech-savvy director	Faster approval of breach-response investments; more targeted second-order questioning (e.g., "What is the MTTR trend?" (P006); "Which vendor access routes failed last time?" (P008)).
In-camera CISO sessions (quarterly)	Clearer ownership of risks; fewer deferred risk-acceptance decisions (e.g., P013 described approving controls in the same meeting rather than deferring to the next quarter).
Independent assurance briefings (≥ annual)	Earlier mitigation of third-party exposures; challenge beyond optimistic internal reporting (e.g., P002 noted tightening vendor due diligence requirements after an external audit contradicted management's view).
Consequence-forward KPIs (e.g., restoration time, incident containment rate)	Decisions explicitly linked to business impact (e.g., restoration-to-SLA used as a trigger for uplift (P006); containment time informing board approval of detection investments (P007)).
Scenario walkthroughs/tabletops (quarterly)	Sharper escalation triggers; improved crisis role clarity (e.g., P010 reported establishing a rule that "if customer data is at risk, the board must be notified immediately").
Short, contextual director education	Improved recall of regulatory triggers and decision obligations; more consistent questioning across directors (e.g., P009 noted directors citing notification duties during simulations instead of deferring to legal counsel).
Traditional risk register with board engagement	Visibility across enterprise risks, but continued concern about the stability and validity of risk ratings (e.g., P003 queried why several cyber risks remained unchanged for 18 months despite repeated incidents).
Maturity frameworks with external verification	Greater regulatory assurance; maturity uplift decisions strengthened when paired with outcome KPIs (e.g., P007 described using "Level 2->3 uplift" only when validated by data from prior events).
Vulnerability management as a discipline	Reduced noise in reporting; improved confidence in baseline posture (e.g., P006 described patch-exception tracking reducing "recurring surprises" in the board pack).
Metrics-based strategies (esp. in education)	Clear accountability for uplift; KPIs directly shaping director challenge (e.g., P005 described tracking simulation and training metrics to test improvement claims).
Holistic, integrated strategies (enterprise risk embedding)	Stronger resilience framing in board discussions (e.g., P009 described shifting investment decisions from "compliance fixes" toward continuity-impact assessments following a supplier outage).

maturity scores illustrated this gap. Second, higher-quality decisions were linked to boards that combined structural capabilities (cyber-savvy members, independent challenge, escalation triggers) with strong information flows and regular cadence with the CISO. Third, incident governance was often the weakest link: playbooks, simulations, and role clarity were patchy, leaving responses reactive.

These findings also suggest that information bottlenecks do not originate solely within the boardroom. Several participants (e.g., P002, P006, P008, P010) noted that security reporting from management or risk teams lacked clarity or prioritisation. This underscores that effective cyber governance also depends on upstream information flows, placing some responsibility with executive teams and reporting structures, not just directors. Future work could further examine this interplay between information preparation and oversight quality.

Overall, cybersecurity governance practices were fragmented and unevenly adopted, with a tendency to reduce oversight to procedural compliance. Yet directors across sectors expressed common needs: consequence-driven metrics, disciplined information flows, and repeatable governance routines that connect obligations to board-level decision-making. These patterns inform the Board Cyber Governance Model proposed in this study, which includes targeted educational and strategic interventions to support more informed and effective governance.

5 Proposed Board Cyber Governance Model

Building on the findings in Section 4, we synthesise cross-cutting themes into a proposed model of board-level cyber governance. Directors in our study highlighted persistent gaps in literacy, unevenly applied oversight artefacts, fragile incident routines, and ad hoc learning. They also shared examples of effective practices, such as consequence-driven KPIs, pre-agreed thresholds, and in-camera CISO sessions. This paper presents a Board Cyber Governance Model that synthesises these patterns into a descriptive governance

framework. The Board Cyber Governance Model synthesises practices observed across participants, distinguishing between governance arrangements associated with more confident, consequence-aware decision-making and those linked to uncertainty, reliance on proxies, or delayed escalation. It outlines the capabilities boards must develop, the enabling routines and artefacts, and the governance outcomes they can support. Rather than prescribing a universal blueprint, it offers a *minimum viable governance package*: literacy that anchors fiduciary duties, consequence-forward oversight mechanisms, credible incident engagement, and continuous learning. The model distils both existing good practices observed in pockets across participants and aspirational capabilities described as desirable but inconsistently applied. As such, it is not meant as a binary assessment of maturity but as a directional framework for enhancing board-level governance. We now outline the four core dimensions that constitute this model.

5.1 Four Dimensions of the Governance Model

The proposed model reflects a governance-led approach: boards hold accountability for oversight but are not expected to perform technical analysis or interpret regulatory detail directly. Parsing legal and technical complexity into decision-useful form is a shared responsibility: boards set expectations for clarity, while subject-matter experts in legal, risk, and cyber teams operationalise interpretation. Effective governance depends on structured interfaces between these actors. This study identifies structural and procedural routines that support or undermine those engagements, such as pre-agreed thresholds, playbook familiarity, and consequence-oriented metrics.

The proposed Board Cyber Governance Model rests on four reinforcing dimensions. Figure 3 provides a visual overview of how these four dimensions interact, reinforcing each other in a cyclical governance model. *Regulatory and fiduciary literacy* enables directors to examine management narratives critically; *oversight mechanisms* provide decision-useful information; *structured incident engagement* fosters trust; and *continuous learning and capability building* compound organisational resilience. Together, these dimensions operate as a governance flywheel, where progress in one area strengthens and accelerates progress in the others. Participants frequently described this dynamic in practice: for instance, improved literacy sharpened their questioning of assurance artefacts, while clearer metrics often exposed weaknesses in incident preparedness. The model, therefore, reflects patterns observed in boardroom experience rather than an abstract ideal.

Each dimension can be interpreted along a spectrum—from absent to emergent to embedded—rather than as a binary state. While this study did not quantify participant alignment across dimensions, qualitative differences in maturity were evident. Boards varied in how consistently they engaged CISOs, interpreted metrics, or rehearsed incident response.

Dimension 1: Regulatory and Fiduciary Literacy

Boards must be able to place cybersecurity within their fiduciary duties. Literacy means directors can explain, in plain language, the organisation's core obligations (privacy, security, disclosure), identify the regulatory triggers that apply (e.g., notification clocks, disclosure thresholds), and articulate how these map to board responsibilities. As one director put it,

> *"We don't need to be engineers, but we do need to understand what triggers our disclosure duties" (P007).*

Several participants (e.g., P002, P005, P007) acknowledged gaps in cyber literacy, particularly when engaging with technical or legal material. Many reported difficulty asking informed questions or interpreting metrics without relying heavily on intermediaries. Others (e.g., P004, P011) described how targeted briefings and structured education sessions had improved their ability to contribute meaningfully to cybersecurity governance.

Dimension 2: Oversight Mechanisms for Decision-Usefulness

Several directors (e.g., P006, P008, P010) emphasised that timely, consequence-linked information was central to their ability to oversee cyber risk effectively. Others noted gaps in cadence or depth of materials. Oversight requires artefacts and routines that translate technical posture into business choices. These include consequence-forward KPIs (e.g., mean-time-to-detect, mean-time-to-restore), dashboards designed for board sense-making, and pre-agreed escalation thresholds. When well-executed, these mechanisms enable directors to act on signals with clarity and timeliness, rather than reactively responding to static reports.

Dimension 3: Structured Incident Engagement

Across interviews, directors (e.g., P003, P008, P012) highlighted uncertainty about roles and escalation pathways during cyber incidents. Many reported that incident playbooks were either missing, out of date, or not rehearsed. A few (e.g., P006, P009) described table-top simulations or post-incident reviews as critical practices for preparedness. These observations point to an urgent need for clearer protocols and structured board engagement throughout the incident lifecycle. Boards must play a credible role before, during, and after major incidents. This means early notification protocols, clear role delineation, scripted updates, and post-incident reviews. Effective routines preserve trust with regulators, customers, and investors while avoiding ad hoc responses. Embedding these practices into governance frameworks ensures that board engagement during crises is timely, coordinated, and aligned with broader organisational resilience goals.

Dimension 4: Continuous Learning and Capability Building

Participants (e.g., P001, P007, P013) noted that learning often occurred only after an external breach or internal audit triggered attention. Others spoke positively about board-level debriefs, sector-sharing forums, or integrating cyber topics into regular strategy discussions. This suggests variability in how boards treat cyber as an evolving, learnable domain. These insights underscore the importance of formalising learning mechanisms within board routines. Boards need routines that build literacy and oversight over time. Examples include in-camera CISO sessions, regular tabletop exercises, external assurance reviews, and director upskilling. These embed resilience into governance by ensuring lessons from one

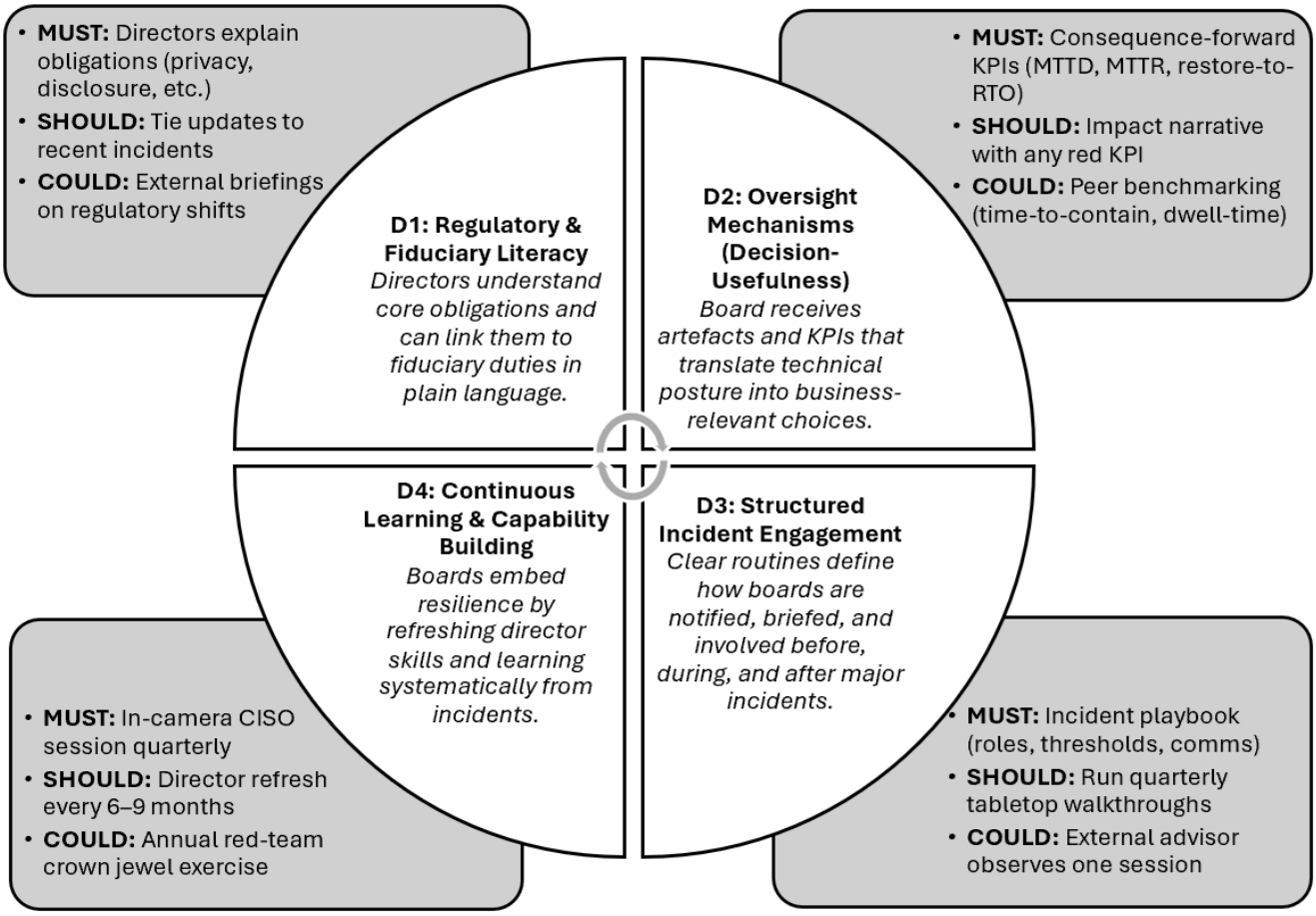


Figure 3: Board Cyber Governance - Proposed Model

incident inform preparedness for the next. Sustained capability building also helps boards keep pace with evolving threats, regulatory expectations, and the shifting business impact of cyber risk.

Taken together, the four dimensions form a set of *core governance routines* that boards can tailor to their own risk landscape and organisational structure. The model distils observed experiences into a structured framework, identifying the minimum conditions for credible oversight and the reinforcing routines that contribute to better decision-making over time.

5.2 Board Cyber Governance Model in Practice: Director's Checklist

To support practical application, we translate the model into a structured *Director's checklist*. Rather than prescribing a fixed standard, the checklist adopts a maturity-aware framing. It distinguishes between baseline expectations (MUST), recommended practices (SHOULD), and aspirational enhancements (COULD), allowing boards to apply it flexibly depending on their current capabilities, sector obligations, and strategic priorities.

The model is not designed for uniform implementation. Boards may already have strengths in some areas, while others remain underdeveloped. The checklist, therefore, operationalises the model using a maturity-aware framing, helping boards assess their current posture, identify weaker areas, and focus on the most relevant priorities for their context. Unlike abstract best-practice guidance, this framework is grounded in real governance conversations. It bridges the gap between high-level aspiration and operational oversight by focusing on what boards can realistically do, given their roles, responsibilities, and constraints. It complements existing frameworks such as the AICD's *Practice Statement on Directors' Oversight of Company Compliance Obligations identifies* [58] and Telstra's *Five Knows of Cyber Security* [74], but does so through the lens of lived boardroom experience.

This is not intended as an exhaustive or universally prescriptive list. It reflects what directors in our study identified as useful, absent, or difficult to govern. The framing helps boards assess where they are now, not just where they should be. Importantly, the checklist separates governance from execution. Boards are not expected to perform technical tasks or write playbooks, but they must ensure

appropriate visibility, accountability, and investment to support these capabilities.

MUST - baseline practices every board should adopt:

- Receive *consequence-forward* metrics during each cycle (e.g., MTTD, MTTR, restore-to-RTO, backup restore success, coverage of high-risk vendors, patch compliance for crown jewels).
- Hold at least quarterly *in-camera* CISO sessions; formally record escalation thresholds and risk appetite statements.
- Commission an independent annual challenge (internal audit and/or external test or red team) and monitor follow-up actions.
- Approve and maintain an incident governance playbook that clarifies notification triggers, decision rights, and designated spokespersons.

SHOULD - practices that improve oversight quality and responsiveness:

- Run board-level scenario walkthroughs or tabletops each quarter, mapped to current KPIs and critical vendors.
- Require a one-page *impact narrative* with any red KPI: What changes if the trend continues? What decision is requested?
- Maintain a quarterly third-party concentration view with remediation commitments and dates.
- Schedule a short, contextual director education refresh every 6–9 months tied to recent incidents and metrics.

COULD - enhancements that support long-term capability building:

- Commission a targeted red team on one crown-jewel business process each year; debrief in the boardroom.
- Ask for time-to-contain and dwell-time estimates after significant incidents and compare to peer benchmarks.
- Invite an external advisor to observe one board cyber session annually and provide feedback on information quality.

The checklist provides a way for boards to assess current posture, identify capability gaps, and prioritise areas for improvement. It reinforces the flywheel logic of the model: progress in one area can build momentum in others, while unresolved weaknesses, such as unclear decision rights or weak reporting, can stall governance maturity. Together, the model and checklist highlight the structural conditions and board-level routines that shape higher-quality cyber decision-making. The discussion that follows situates these contributions within broader governance and risk-management literature and outlines implications for board and regulatory practice.

6 Discussion

Our findings portray boards as *highly exposed* to cyber risk, yet inconsistent in how they govern it. The inconsistency is not due to lack of awareness as most directors are well aware of the stakes. Rather, the inconsistency stems from structural weaknesses: poor-quality information, capability gaps, and fragile incident response routines that hinder the translation of awareness into effective governance. These challenges mirror patterns observed in other jurisdictions, where boards must navigate the tension between compliance artefacts, business context, and resilience objectives [13, 55]. In this section, we interpret our findings through three cross-cutting themes aligned to our research questions (RQ1-RQ3), and reflect on their broader implications for cyber governance theory and practice.

6.1 From compliance to consequence (RQ1)

Our findings reveal that while most boards receive a relatively standard set of cyber inputs, such as posture snapshots, incident trend lines, and compliance logs, their ability to translate these artefacts into meaningful oversight varies significantly. This variation is not primarily due to a lack of awareness, but rather to structural and contextual factors that shape how information is interpreted and acted upon. The form and framing of information, therefore, strongly influence board engagement. Directors expressed a clear preference for consequence-forward metrics over abstract maturity scores, which were often viewed as easy to manipulate and difficult to tie to real-world outcomes. This suggests that what gets measured and how it is presented plays a critical role in enabling informed oversight. Boards are not just passive recipients of information; they rely on structured, decision-useful reporting to calibrate risk appetite and evaluate trade-offs.

Artefact value generation. Reporting remains dominated by compliance artefacts, e.g.,dashboards, audits, regulatory updates, yet these do not always help directors prepare for upcoming decisions. Directors repeatedly questioned whether maturity ladders or traffic-light dashboards conveyed anything useful about resilience. Several directors emphasised that weaknesses in oversight often stemmed from upstream information bottlenecks in management and security teams, indicating that governance improvements must be paired with stronger reporting and translation practices. One director noted:

> *"It can be easy to think everything is fine in your department, but you need to hear from others to really understand where the risks are."* (P001)

At the same time, compliance was rarely dismissed outright. It was seen as necessary but not sufficient:

> *"More compliance does not equal less risk—it becomes a tick-boxing exercise for assurance rather than real reduction."* (P004)

This tension between compliance and consequence is not unique to our cases. Similar concerns appear in global studies of board reporting. What stood out here was the frustration with static artefacts that look polished but do not explain what they mean for business continuity or risk appetite in the next quarter.

A further nuance lay in sectoral context. Financial services directors, operating under APRA's CPS 234, tended to see compliance artefacts as unavoidable and even useful, since they aligned with external reporting obligations. By contrast, directors from education and startup boards described the same artefacts as burdensome and disconnected from operational reality. In practice, this meant a risk register or compliance log might be received with relief in one setting but with scepticism in another. The reporting format also shaped reactions. Traffic-light dashboards were remembered by almost every participant, but their value depended on the accompanying narrative: when presented with only colours, directors admitted they struggled to know what was at stake; when paired with a short consequence story, such as what "red" meant for service

continuity in the next quarter, they felt better equipped to make informed decisions. This unevenness highlights that the artefact itself is not the problem; it is the framing that determines whether the board can link compliance status to real governance choices.

Foundational legal and regulatory knowledge. Director knowledge of legal and regulatory obligations is also clearly uneven. Based on our interviews, these are often shaped by sector exposure, prior experience, and organisational size. While privacy and breach-notification duties were widely recognised, more technical or sector-specific frameworks (e.g., CPS 234, ISO 27001) were less consistently understood. This supports proposition P1, highlighting that governance effectiveness is partly contingent on directors' familiarity with relevant standards. In addition, external assurance emerged as a key enabler of board confidence, particularly in challenging management perspectives and validating internal reporting. Where assurance was routine, directors felt better equipped to interrogate risk posture and make timely decisions. This reinforces the idea that governance artefacts are only as effective as the routines and capabilities that surround them.

6.2 Capability, cadence, and challenge (RQ2)

Our findings suggest that high-quality cyber decision-making, defined as timely, evidence-based, consequence-aware, and auditable, is not the product of any single factor, but rather the interaction of board composition, information quality, and governance routines. RQ2 helps move beyond descriptive oversight to identify the conditions under which boards can make better cyber decisions. We found that higher-quality decisions were consistently associated with three conditions, though the balance varied between boards.

Capability. Even modest cyber literacy shifted discussions. As one director stressed:

> *"Directors don't need to be technical experts, but they need to be literate enough to interrogate management without getting lost in jargon."* (P013)

Where this literacy was missing, boards often defaulted to accepting management narratives. Several participants pointed to education as a partial remedy, but not generic e-learning. They recommended tailored workshops that translated technical detail into business impact, and for regular refreshers rather than one-off sessions. Some directors also leaned on external consultants to provide independent briefings and "plain-speak" interpretation. Others argued for bringing at least one technically experienced director onto the board to diversify perspectives. A few mentioned critical thinking training more generally, not about cyber per se, but about sharpening directors' ability to challenge information.

Additionally, directors were clear that generic e-learning modules were of little value; what they asked for were tailored workshops that translated technical concepts into business consequences and could be refreshed regularly as threats evolved. Several emphasised the role of external experts in bridging gaps between management and the board, noting that an objective briefing from consultants often cut through internal optimism and provided language directors could use in challenge [32, 36]. Others pointed to the importance of cognitive diversity, recalling cases where a director with a digital or IT background shifted the tone of discussions and pushed the board beyond surface-level assurance. At the same time, participants stressed that expertise should not be confined to one seat. This supports proposition P2, which links preferred risk strategies to perceived exposure and organisational priorities. As one director observed, boards also need broader critical thinking skill, such as the ability to interrogate assumptions, weigh evidence, and ask probing questions, even if they are not cyber specialists. Considered together, these strategies highlight that capability is built less through technical depth and more through sustained literacy, diversity of perspective, and the confidence to challenge management when it matters.

Cadence. Directors consistently emphasised the importance of plain-language reporting, consequence-forward KPIs, and clearly defined escalation thresholds. These features enabled boards to move from passive oversight to active decision-making. In addition, engagement with the CISO mattered as much as formal artefacts. In-camera sessions were described by directors as where the real issues surfaced. It also aligns with proposition P4, which links active board engagement to stronger resilience postures. As one participant put it:

> *"Boards must change their understanding of risks and see cyber as a living process, not a one-off register."* (P002)

However, this cadence was not universal. Some boards saw the CISO only when a major incident occurred, which meant they lost continuity and context. Cadence also varied sharply by sector. In heavily regulated domains such as financial services or government, directors described regular sessions with the CISO as a matter of compliance expectation, often tied to prudential standards or internal audit schedules. These routines created a predictable rhythm of engagement, and several directors said they relied on them to calibrate risk appetite and ensure issues were surfaced before incidents. By contrast, startup and education boards admitted that cyber appeared only intermittently on the agenda, usually triggered by a recent breach in the news or an operational disruption. In these settings, cadence was reactive and ad hoc, leaving boards without the continuity needed to track trends or probe assumptions. This divergence underscores what prior work highlights: the board–CISO relationship is less about the artefacts exchanged than the regularity of dialogue, which anchors oversight and allows directors to build confidence in their own questions.

Challenge. External assurance, whether through internal audit, red-teaming, or third-party reviews, was seen as a critical counterweight to management narratives. It gave directors confidence to challenge assumptions and calibrate risk appetite. This reinforces the idea that assurance is not just a compliance tool but a governance enabler, particularly when it is tied to business outcomes rather than abstract maturity scores. As one director explained:

> *"External reviews help us test whether management's view is too optimistic or whether we're actually prepared."* (P008)

Yet not every board sought such input. A few relied almost entirely on management updates, which left them exposed to optimistic reporting. Views on external challenge were also not uniform. Several directors welcomed independent audits, red-team reports, or penetration tests, arguing that they provided a necessary counterweight to management's often optimistic framing and gave the board defensible grounds for investment or escalation.

Others, particularly from smaller or resource-constrained organisations, regarded such exercises as costly or disruptive, and preferred to rely on management's internal reporting unless regulators demanded more. This divergence reflects a broader tension in the literature: external assurance is consistently linked to stronger oversight credibility, but boards vary in how much they are willing to invest in it. This diversity supports proposition P2, highlighting that governance strategies are not one-size-fits-all but reflect how boards interpret and prioritise cyber risk. The interviews suggest that where external challenges are routine, directors feel more confident in their judgments; where they are absent, decision-making remains anchored to internal narratives, and the risk of blind spots increases.

Together, these findings suggest that improving cyber decision quality at board level requires more than technical briefings or regulatory updates. It demands a governance environment where directors are equipped, informed, and engaged, supported by routines that translate signals into decisions. Boards that invest in these capabilities are better positioned to move from reactive oversight to proactive resilience.

6.3 Incidents as governance moments (RQ3)

RQ3 shifts the focus from routine oversight to crisis governance: how boards engage before, during, and after major cyber incidents, and which practices are linked to faster recovery and reduced harm. The findings suggest that resilience is not just a function of technical preparedness, but of governance structures that enable timely, coordinated, and informed board involvement.

Role clarity and escalation thresholds. Directors consistently emphasised the need for early notification and clearly defined decision rights. Board involvement was expected to scale with incident materiality, particularly where customer data, service continuity, or reputational risk were at stake. This supports proposition P3, which highlights that perceived incident capability is shaped by prior events, available resources, and governance frameworks. In this context, incidents served as stress tests, but participants clarified that practices varied widely. Several directors emphasised the importance of disciplined notification: early enough to enable oversight, but not so rushed that it creates confusion. One director warned:

> *"Rushing to provide information can backfire; you need accuracy and timeliness, even if that means saying less in the first hour."* (P010)

Other directors raised concerns about thresholds, noting that the ratings presented in board packs often failed to reflect actual business impact. As one observed:

> *"Data-related incidents now trigger urgent board action–system availability is as critical as confidentiality."* (P007)

Learning loops. Some boards rehearsed scenarios with playbooks and after-action reviews; others admitted they had not. Boards that consistently reviewed post-incident lessons alongside targeted investments and policy updates were found to be better positioned to evolve their oversight practices. These feedback loops helped boards move from reactive to proactive governance, for example by introducing restoration-time KPIs or segmentation controls after a breach. This aligns with proposition P4, which links active board engagement in learning and governance processes to stronger resilience outcomes. Without these loops, incidents risk being treated as isolated IT failures rather than systemic learning opportunities. In this respect, our findings echo international work showing that playbooks and simulations are as important as technical investment.

However, experience with playbooks and rehearsals proved to be a dividing line. Directors in larger or highly regulated organisations described structured exercises where the board and management rehearsed communication flows and escalation steps. These sessions gave them greater confidence during real incidents, with one noting that even a partial rehearsal helped reduce duplication and panic when events unfolded. In contrast, directors from smaller or less resourced boards admitted that they lacked such routines. In those cases, the first real incident often became the rehearsal, producing delays and mixed messages that undermined both internal coordination and external trust.

Pragmatic leadership. Anxiety about reputational fallout was a recurring theme. Several participants emphasised that poorly handled communications could magnify the impact of an incident more than the technical breach itself. Those who had practised responses felt they could balance accuracy and timeliness more effectively, even if that meant holding back details until confirmed. Others worried that without clear thresholds or agreed triggers, boards were left debating "materiality" in real time, slowing decisions and exposing the organisation to criticism. Additionally, regulatory clocks intensified these pressures. Australian directors pointed to the Notifiable Data Breaches scheme, which requires entities to assess a suspected breach within 30 days and then notify affected individuals (and the regulator) "as soon as practicable" once an eligible breach is confirmed, as a driver of quicker escalation. Those with multinational experience contrasted it with the SEC's new four-day disclosure rule. In both cases, the countdown created urgency but also heightened the risk of premature or incomplete communication. Boards that had rehearsed under such constraints felt more prepared; those encountering them for the first time described the process as chaotic and stressful. Taken together, these accounts highlight that resilience depends as much on governance routines and regulatory readiness as on technical controls. This reflects a broader theme in the data: effective incident governance is less about rigid structures and more about clarity, competence, and coordination.

Boards that are prepared to act during major incidents do not rely solely on formal policies or reactive briefings. Instead, they invest in routines that clarify roles, discipline communication, and embed learning. These practices not only reduce harm during crises but also build organisational resilience over time. RQ3 thus highlights the board's role not just as overseer, but as an active participant in shaping the organisation's capacity to withstand and recover from cyber shocks.

6.4 Policy and global practice

While our study was rooted in the Australian context, its relevance extends beyond national borders. The study aligns with globally recognised frameworks such as GDPR, NIS2 Directive, ISO 27001, and the US SEC's cybersecurity disclosure rules. From this comparative lens, three practices emerge as globally portable: the use

of consequence-driven KPIs, structured in-camera cadence with CISOs, and assurance mechanisms that explicitly connects compliance efforts to operational resilience. However, jurisdictional nuances, such as breach notification timelines or prudential reporting obligations, introduce distinct triggers that shape implementation and oversight.

Prescribed framework vs. mandated reporting. For regulators, mandating consequence-forward reporting and role clarity may prove more effective than prescribing frameworks. Our interviews suggest that prescribing frameworks alone are unlikely to close governance gaps. Directors repeatedly emphasised that compliance artefacts are necessary but insufficient for decision-useful oversight. A more effective lever may be to mandate consequence-forward reporting and role clarity, similar to existing expectations in prudential standards. Several participants also pointed to the absence of consistent director education requirements, contrasting cyber with financial literacy mandates that already exist for boards. Introducing baseline education standards or periodic upskilling requirements could help reduce the uneven literacy observed across sectors and ease the translation of technical risk into business terms.

Differences of views surfaced where Australian directors described APRA's CPS 234 as enforcing structured cadence and reporting, while their peers with multinational roles pointed to the SEC's four-day disclosure rule as more demanding. The European context, with GDPR and NIS2, added yet another layer of obligations, particularly on breach notification and liability. These differences underscore that while practices such as consequence-forward KPIs, in-camera CISO sessions, and independent assurance appear portable across jurisdictions, the timing and thresholds for disclosure remain highly localised. Boards navigating multiple laws and standards must therefore adapt routines to the strictest standard while maintaining clarity on which obligations apply in each context.

Formal artefacts and continuous upskilling. For boards, the implication is blunt: artefacts alone do not guarantee oversight; routines matter, so the investment in training and composition is no longer optional. Boards that rely on generic awareness sessions or management-led briefings tend to struggle to interrogate metrics, while those that seek tailored education and external perspectives are better able to challenge assumptions. A few participants argued that adding a single "cyber seat" could distort accountability; instead, the emphasis should be on spreading literacy across the board and leveraging cognitive diversity. Recruiting directors with digital or risk backgrounds, combined with critical thinking training for all members, was seen as a way to ensure cyber discussions were not siloed but integrated into broader governance.

6.5 Governance Capability Beyond Compliance

Synthesising insights from RQ1 through RQ3, cyber governance emerges not as a static checklist but as a reinforcing cycle. Obligations and standards set the inputs; board-CISO cadence, consequence-oriented KPIs, and independent challenge shape interpretation; and board decisions on investment, disclosure, and crisis communication produce outcomes in resilience and trust. Lessons then cycle back through reviews and director development. In this way, our proposed Board Cyber Governance Model integrates the tensions in reporting (RQ1), the conditions for higher-quality decision-making (RQ2), and the routines that shape incident governance (RQ3).

To illustrate how the cycle can work in practice, one director (P008) described how an external red-team style review highlighted gaps in vendor access controls and forced management to rethink its optimism. The results were brought to the board in plain language, alongside consequence-oriented measures of recovery time and potential service disruption. Within weeks, the board approved additional investment in monitoring and third-party due diligence, a decision they felt was defensible precisely because it linked posture to business continuity. In this way, artefacts gained traction not because they complied with a framework, but because they were embedded in routines that supported timely sense-making and action. While this case shows how the cycle can accelerate under the right conditions, the pattern was not universal. The cycle played out differently depending on organisational size. Larger, regulated entities often had the resources to maintain structured cadence, external assurance, and ongoing director training, which meant the loop from input to decision to outcome was relatively continuous. Smaller organisations, by contrast, tended to treat incidents or regulatory triggers as the main catalysts for action, with long gaps in between. For them, the cycle was more fragile: each weak link, whether in cadence, literacy, or challenge, slowed the feedback loop and left boards exposed until the next disruption forced attention.

Participants further stressed that incident reviews were a crucial source of learning, not only for management but for directors themselves. Several noted that after-action reports and crisis debriefs often prompted adjustments to board education, with lessons feeding back into tailored workshops or targeted briefings. In this sense, resilience was not just about recovering systems but about embedding organisational memory into governance routines. Boards that treated incidents as learning opportunities were more likely to build cumulative capability, whereas those that viewed them solely as compliance events risked repeating the same vulnerabilities. Therefore, the proposed model aims to reframe cyber maturity as a governance capability: the ability to turn obligations into timely, auditable, and consequence-aware decisions, where strong routines accelerate the cycle, while weak links stall it. In practice, the proposed model is less about perfect security and more about consistent governance routines that enable boards to act with confidence.

7 Validity, Limitations, and Trustworthiness

This section assesses the validity of our findings, acknowledging limitations, and establishing the trustworthiness of our interpretations.

Sampling and scope. Our sample comprises 13 participants (directors and C-suite) across multiple sectors and organisation sizes in Australia. Their seniority gave access to board-facing practices and decision rationales, but may bias toward large, regulated entities and relatively well-governed settings. Smaller, founder-led, or highly distributed boards are less represented.

Researcher reflexivity and procedures. We worked from an interpretivist stance and used reflexive memoing before, during, and after interviews to surface assumptions about perceived "good"

board practice. Each interview was co-facilitated to balance participation and reduce leading prompts. Analysis followed an explicit audit trail (versioned codebook, decision logs) and included a double-coding slice with reconciliation meetings (Cohen's κ on the calibration subset). We actively searched for disconfirming evidence, such as cases where high maturity scores did map to faster recovery, and recorded them in memos.

Analysis credibility. Reflexive thematic analysis was combined with light computational support (tokenisation, topic modelling) to organise the corpus, but human interpretation defined themes. Short quotes anchor claims to participants' words. Recurring patterns on board-pack content, assurance use, and incident role clarity suggested saturation, though we do not claim exhaustion.

Bias and mitigation. Elite interviews carry risks of social-desirability and recall bias. We mitigated these through confidentiality assurances, anonymised reporting, and prompts for concrete examples (e.g., last board pack, last tabletop, last external review). Triangulation came from participants serving on multiple boards. As an interview study, we did not observe meetings directly; future observational work could validate the routines described.

Transferability. Although based in Australia, the patterns we observed resonate with widely adopted global anchors such as ISO 27001, the NIST CSF, breach-notification clocks, independent assurance, and third-party oversight. Building on the literature review and our synthesis of interview findings, we outline *core governance routines* in the proposed model: consequence-forward KPIs, regular CISO cadence (including in-camera sessions), independent challenge, scenario-based director education, and supplier risk oversight. These routines can be parameterised to local regulators, timelines, and materiality thresholds. We argue for *analytic*, rather than statistical, generalisation: the routines are applicable wherever boards face comparable obligations and complexity.

Limitations. Key limits are the small, non-random sample; reliance on self-reporting; single-jurisdiction context; and absence of direct performance outcomes (e.g., measured restoration times). While these constraints are appropriate for this study's exploratory aim of understanding user practices and contextual conditions, future research should incorporate complementary methods to enhance generalisability and empirical depth.

8 Conclusion and Future Work

This study addresses the persistent *translation problem* at board level: how to convert technical posture and compliance artefacts into *decision-useful* oversight that enables faster, better-justified choices, and incident routines designed to reduce harm. From interviews with directors and senior executives, we contribute:

(1) **Empirical characterisation of board-level cyber governance** (RQ1). We provide an empirical review of what cyber oversight currently looks like in practice, what information boards actually receive, what they pay attention to, and where decisions are made or deferred. This includes posture snapshots, incident trends, third-party exposure, and compliance or exception logs, alongside the persistent tension directors described between maturity scores and outcome-oriented KPIs. This contribution establishes the real starting point from which boards are governing cyber risk today.

(2) **Factors linked to higher-quality cyber decisions and confident decision-making.** (RQ2). Across interviews, we identify the governance conditions that directors themselves considered most enabling. For instance, at least one cyber-literate director per board, predictable cadence (e.g., quarterly deep dives and in-camera access to the CISO), and meaningful challenge via independent assurance. These conditions matter because they shape how technical information is interpreted, how risk is contextualised, and how confident directors feel in exercising oversight. We show how consequence-forward narratives and agreed thresholds support more timely, auditable decisions.

(3) **Incident governance practices and gaps** (RQ3). We describe the routines that supported clearer, calmer cyber incident decision-making. For example, early notification triggers, role clarity, communication discipline, and structured after-action learning loops. We also surface common gaps, such as fragmented ownership, inconsistent definitions, and over-reliance on abstract maturity scores during crises. This contribution illustrates why incident performance is tightly coupled to governance preparation, not just technical controls.

(4) **Proposed Board Cyber Governance Model.** (Integrates RQ1–RQ3). Drawing these strands together, we synthesise the empirical insights into a minimum viable governance scaffold comprising literacy, oversight, incident engagement, and learning. The model reflects how directors in our study already navigate cyber risk, not an imagined ideal, and provides a practical structure for strengthening consequence-aware decision-making and organisational resilience. It supports boards in assessing where they currently sit, where gaps cluster, and where improvement is most feasible without imposing a one-size-fits-all standard.

Together, these findings suggest that boards decide better when information is framed for *consequence*, routines enable *challenge*, and incidents are governed as *rehearsed processes* rather than ad hoc crises.

Future work

We outline four avenues to deepen and test these insights:

- **Multi-country replication.** Interview/case-study extensions in the EU, US, and additional Asia-Pacific jurisdictions can examine how the governance spine parameterises to differing regulators, clocks, and materiality rules.
- **Longitudinal board-meeting ethnography.** Non-participant observation of board/committee sessions to validate reported routines, analyse discourse (challenge, framing), and link information quality to decision outcomes over time.
- **Survey to test propositions.** A cross-sectional survey of directors/CISOs to test the propositions in Section 6 (e.g., in-camera cadence $\rightarrow$ time-to-decision; outcome KPIs $\rightarrow$ fewer deferred risk acceptances) with appropriate controls for sector/size.
- **Before/after studies on briefing redesign.** Field experiments that replace maturity-heavy packs with consequence-forward dashboards and explicit thresholds, measuring changes

in decision speed, clarity of minutes, and post-incident recovery metrics.

In conclusion, boards cannot outsource cyber governance to compliance checklists. The path from literacy to oversight to resilient incident handling is a Board Cyber Governance Model in the form of a *governance flywheel* that can be built and matured deliberately. Our contribution is to describe the model components empirically and show how they can travel across jurisdictions with targeted adaptation, based on our study examining how board directors conceptualise and govern cyber risk in real-world organisational contexts.

Acknowledgments

The work has been supported by the Cyber Security Research Centre Limited whose activities are partially funded by the Australian Government's Cooperative Research Centres Program.

References

[1] Australian Institute of Company Directors (AICD) 2019. *Fiduciary duties of directors.* Australian Institute of Company Directors (AICD). https://www.aicd.com.au/board-of-directors/duties/fiduciary.html#:~:text=In%20Australia%2C%20fiduciary%20duty%20is Accessed: 2025-11-11.

[2] Mustafa Abdallah, Daniel Woods, Parinaz Naghizadeh, Issa Khalil, Timothy Cason, Shreyas Sundaram, and Saurabh Bagchi. 2021. Morshed: Guiding behavioral decision-makers towards better security investment in interdependent systems. In *Proceedings of the 2021 ACM Asia Conference on Computer and Communications Security* (Virtual Event, Hong Kong) *(ASIA CCS '21)*. Association for Computing Machinery, New York, NY, USA, 378–392. doi:10.1145/3433210.3437534

[3] Moneer Alshaikh. 2020. Developing cybersecurity culture to influence employee behavior: A practice perspective. *Computers & Security* 98 (2020), 102003.

[4] Ross Anderson. 2001. Why information security is hard - An economic perspective. In *17th Annual Computer Security Applications Conference*. IEEE, 358–365.

[5] Australian Securities and Investments Commission. 2022. Federal Court of Australia decision in 'ASIC v RI Advice Group Pty Ltd'. Retrieved from https://download.asic.gov.au/media/zhodijpp/22-104mr-2022-fca-496.pdf. Accessed: 2/11/2023.

[6] Australian Securities and Investments Commission. 2024. Key Questions for an Organisation's Board of Directors. https://asic.gov.au/regulatory-resources/corporate-governance/cyber-resilience/key-questions-for-an-organisation-s-board-of-directors/. Accessed: 29/05/2024.

[7] Alberto Belalcázar, Mario Ron, Javier Díaz, and Lía Molinari. 2017. Towards a strategic resilience of applications through the NIST cybersecurity framework and the strategic alignment model (SAM). In *2017 International Conference on Information Systems and Computer Science (INCISCOS)*. IEEE, 181–187.

[8] Mariette Bengtsson. 2016. How to plan and perform a qualitative study using content analysis. *NursingPlus Open* 2 (2016), 8–14.

[9] Steven Bird, Edward Loper, and Ewan Klein. 2009. Natural language processing with Python. https://www.nltk.org/.

[10] David M Blei, Andrew Y Ng, and Michael I Jordan. 2003. Latent dirichlet allocation. *Journal of Machine Learning Research* 3, Jan (2003), 993–1022.

[11] Alexander Bogner and Wolfgang Menz. 2009. The theory-generating expert interview: epistemological interest, forms of knowledge, interaction. In *Interviewing experts*. Springer, 43–80.

[12] Virginia Braun and Victoria Clarke. 2019. Reflecting on reflexive thematic analysis. *Qualitative Research in Sport, Exercise and Health* 11, 4 (2019), 589–597.

[13] Vincent Bruni-Bossio. 2020. Keeping boards in the loop: getting directors the right information. *Journal of Business Strategy* 41, 2 (2020), 19–28.

[14] David Byrne. 2022. A worked example of Braun and Clarke's approach to reflexive thematic analysis. *Quality & Quantity* 56, 3 (2022), 1391–1412. doi:10.1007/s11135-021-01182-y

[15] C-Risk. 2024. C-Suite. https://www.c-risk.com/c-suite. Accessed: 29/05/2024.

[16] Canadian Centre for Cyber Security. 2022. ITSAP.10.101 - What is a cyber security risk? https://www.cyber.gc.ca/sites/default/files/2022-07/itsap10101-e.pdf. Accessed: 29/04/2024.

[17] Hasan Cavusoglu, Huseyin Cavusoglu, and Srinivasan Raghunathan. 2004. Economics of IT security management: Four improvements to current security practices. *Communications of the Association for Information Systems* 14, 1 (2004), 3.

[18] Center for Strategic and International Studies (CSIS). 2024. Significant cyber incidents. https://www.csis.org/programs/strategic-technologies-program/significant-cyber-incidents. Accessed: 02/04/2024.

[19] Jing Chen, Elaine Henry, and Xi Jiang. 2022. Is Cybersecurity Risk Factor Disclosure Informative? Evidence from Disclosures Following a Data Breach. *Journal of Business Ethics* 187, 199–224.

[20] Jing Chen, Elaine Henry, and Xi Jiang. 2024. More than malware: unmasking the hidden risk of cybersecurity regulations. *International Cybersecurity Law Review* 5, 169–212.

[21] Ericka Chickowski. 2023. How much cybersecurity expertise does a board need? https://www.csoonline.com/article/656596/how-much-cybersecurity-expertise-does-a-board-need.html. Accessed: 2/11/2023.

[22] George Christou. 2018. The challenges of cybercrime governance in the European Union. *European Politics and Society* 19, 3 (2018), 355–375.

[23] Cybersecurity and Infrastructure Security Agency. 2024. Shields Up: Guidance for corporate leaders and CEOs. https://www.cisa.gov/shields-up. Accessed: 29/04/2024.

[24] Joseph Da Silva and Rikke Bjerg Jensen. 2022. " Cyber security is a dark art": The CISO as soothsayer. *Proceedings of the ACM on Human-Computer Interaction* 6, CSCW2 (2022), 1–31.

[25] Duy Dang-Pham, Nik Thompson, Atif Ahmad, and Sean Maynard. 2025. Shadow Information Security Practices in Organizations: The role of information security transparency, overload, and psychological empowerment. *Computers & Security* 156 (2025), 104538.

[26] Deloitte. 2023. Heads up — SEC issues new requirements for cybersecurity disclosures. 30, 13 (July 2023). https://dart.deloitte.com/USDART/pdf/e1131b39-e308-409a-a094-ffbd02af409f

[27] Stefanie Döringer. 2021. 'The problem-centred expert interview'. Combining qualitative interviewing approaches for investigating implicit expert knowledge. *International Journal of Social Research Methodology* 24, 3 (2021), 265–278.

[28] Kizzy Gandy. 2024. How many interviews or focus groups are enough? *Evaluation Journal of Australasia* 24, 3 (2024), 211–223.

[29] Gartner. 2024. Document 4013892. https://www.gartner.com/en/documents/4013892. Accessed: 29/05/2024.

[30] S.S. Girn. 2024. *Cybersecurity Governance Framework for Board Directors.* Ph. D. Dissertation. University of Technology Sydney. Master's/PhD thesis.

[31] Yaniv Harel and Abraham Carmeli. 2025. A strategic cybersecurity oversight framework: a board's imperative. *Journal of Cybersecurity* 11, 1 (2025), tyaf021. doi:10.1093/cybsec/tyaf021

[32] Caroline C Hartmann and Jimmy Carmenate. 2021. Academic research on the role of corporate governance and IT expertise in addressing cybersecurity breaches: Implications for practice, policy, and research. *Current issues in auditing* 15, 2 (2021), A9–A23.

[33] Monique Hennink and Bonnie N Kaiser. 2022. Sample sizes for saturation in qualitative research: A systematic review of empirical tests. *Social science & medicine* 292 (2022), 114523.

[34] Jonas Hielscher, Uta Menges, Simon Parkin, Annette Kluge, and M Angela Sasse. 2023. "Employees Who Don't Accept the Time Security Takes Are Not Aware Enough": The CISO View of Human-Centred Security. In *32st USENIX Security Symposium (USENIX Security 23), Boston, MA*.

[35] Klaus J. Hopt. 2017. The dialogue between the chairman of the board and investors: The practice in the UK, the Netherlands and Germany and the future of the German Corporate Governance Code under the new chairman. *ECGI - Law Working Paper No. 365/2017* (September 2017). Available at SSRN: https://ssrn.com/abstract=3030693 or http://dx.doi.org/10.2139/ssrn.3030693.

[36] Md Shariful Islam and Thomas Stafford. 2017. Information Technology (IT) integration and cybersecurity/security: the security savviness of board of directors. (2017).

[37] Eve Jenkins, Dinislam Abdulgalimov, Pamela Briggs, Patrick Olivier, and James Nicholson. 2025. Using Anonymous Discussion Platforms to Support Open Conversations about Cybersecurity in Organisations. In *Proceedings of the CHI Conference on Human Factors in Computing Systems (CHI '25)*. ACM, New York, NY, USA, 1–14. doi:10.1145/3706598.3713290

[38] Wall Street Journal. 2025. Cybersecurity: The Internal Threats Boards Overlook. https://www.wsj.com/tech/cybersecurity/cyber-security-internal-threats-4d4c70dd. Accessed: 2025-09-03.

[39] Deep Kakkar and Lori Gordon. 2018. Envisioning alternate futures will change our thinking about cybersecurity. In *Journal of The Colloquium for Information Systems Security Education*, Vol. 6. 20–20.

[40] Jong-Seok Kim and Dongsu Seo. 2023. Foresight and strategic decision-making framework from artificial intelligence technology development to utilization activities in small-and-medium-sized enterprises. *foresight* 25, 6 (2023), 769–787.

[41] KPMG. 2023. SEC's final cybersecurity rules: A board lens. https://assets.kpmg.com/content/dam/kpmg/xx/pdf/2023/09/sec-final-cybersecurity-rules-a-board-lens.pdf

[42] David F Larcker, Peter C Reiss, and Brian Tayan. 2017. Critical update needed: Cybersecurity expertise in the boardroom. *Rock Center for Corporate Governance at Stanford University Closer Look Series: Topics, Issues and Controversies in Corporate Governance No. CGRP-69, Stanford University Graduate School of Business Research Paper* 17-70 (2017).

[43] Seth C Lewis, Rodrigo Zamith, and Alfred Hermida. 2013. Content analysis in an era of big data: A hybrid approach to computational and manual methods. *Journal of broadcasting & electronic media* 57, 1 (2013), 34–52.
[44] Michelle Lowry, Anthony Vance, and Marshall D. Vance. 2021. Inexpert supervision: Field evidence on boards' oversight of cybersecurity. https://ssrn.com/abstract=4002794 or http://dx.doi.org/10.2139/ssrn.4002794. Accessed: 02/04/2023.
[45] Michelle René Lowry, Zeynep Sahin, and Anthony Vance. 2022. Taking a seat at the table: The quest for CISO legitimacy. In *ICIS 2022 Proceedings*. https://aisel.aisnet.org/icis2022/security/security/14
[46] Jyoti D Mahadeo, Teerooven Soobaroyen, and Vanisha Oogarah Hanuman. 2012. Board composition and financial performance: Uncovering the effects of diversity in an emerging economy. *Journal of business ethics* 105 (2012), 375–388.
[47] Yassine Maleh, Abdelkebir Sahid, and Mustapha Belaissaoui. 2021. A maturity framework for cybersecurity governance in organizations. *EDPACS* 63, 6 (2021), 1–22.
[48] Deb McCaffrey and Jessica Kelley. 2022. Cybersecurity and research are not a dichotomy: How to form a productive operational relationship between research computing and data support teams and information security teams. In *Practice and Experience in Advanced Research Computing*. 1–4.
[49] Joshua McLeod, Shaun Star, and David Shilbury. 2023. Board composition in national sport federations: A cross-country comparative analysis of diversity and board size. *Managing Sport and Leisure* 28, 6 (2023), 714–731.
[50] Anita Modi, Ievgeniia Kuzminykh, and Bogdan Ghita. 2023. Data driven approaches to cybersecurity governance for board decision-making– A systematic review. *arXiv preprint arXiv:2311.17578* (2023).
[51] National Cyber Security Centre. 2016. Common cyber attacks: Reducing the impact. https://www.ncsc.gov.uk/guidance/white-papers/common-cyber-attacks-reducing-impact. Accessed: 02/02/2024.
[52] National Cyber Security Centre. 2020. Cyber security governance: The role of the board. https://www.ncsc.gov.uk/blog-post/cyber-security-governance-the-role-of-the-board. Accessed: 29/05/2024.
[53] National Cyber Security Centre (NCSC). 2024. NCSC Board Toolkit. https://www.ncsc.gov.uk/collection/board-toolkit. Accessed: 02/04/2024.
[54] Pat Niemann. 2025. *Cyber and AI Oversight Disclosures: What Companies Shared in 2025*. Harvard Law School Forum on Corporate Governance. https://corpgov.law.harvard.edu/2025/10/28/cyber-and-ai-oversight-disclosures-what-companies-shared-in-2025/ Accessed: 2025-11-20.
[55] Yuri Nieto, Vicente Gacía-Díaz, Carlos Montenegro, Claudio Camilo González, and Rubén González Crespo. 2019. Usage of machine learning for strategic decision making at higher educational institutions. *Ieee Access* 7 (2019), 75007–75017.
[56] Sara Nodehi, Tim Huygh, and Laury Bollen. 2024. Six board roles for information security governance. In *International Conference on Enterprise Information Systems, ICEIS-Proceedings*, Vol. 2. Springer, 713–720.
[57] Niki O'Brien, Roberto Fernandez Crespo, Fiona O'Driscoll, Mabel Prendergast, Deeph Chana, Ara Darzi, Saira Ghafur, et al. 2024. Usability and feasibility evaluation of a web-based and offline cybersecurity resource for health care organizations (The essentials of cybersecurity in health care organizations framework resource): Mixed methods study. *JMIR Formative Research* 8, 1 (2024), e50968.
[58] Australian Institute of Company Directors. 2024. *Cyber Security Governance Principles*. Technical Report. Australian Institute of Company Directors. https://www.aicd.com.au/risk-management/framework/cyber-security/cyber-security-governance-principles.html
[59] Australian Institute of Company Directors. 2024. *Governing Through a Cyber Crisis - Cyber Incident Response and Recovery for Australian Directors*. Technical Report. Australian Institute of Company Directors. https://www.aicd.com.au/risk-management/framework/cyber-security/governing-through-a-cyber-crisis-cyber-incident-response-and-recovery-for-australian-directors.html
[60] National Association of Corporate Directors (NACD). 2024. Nora Denzel and David Kenny to Co-Chair the 2024 NACD Blue Ribbon Commission on Board Oversight of Technology. https://www.nacdonline.org/about/NACD-in-the-news/press-release/nora-denzel-and-david-kenny-to-co-chair-the-2024-nacd-blue-ribbon-commission-on-board-oversight-of-technology/?Refid=newsletter Retrieved from the National Association of Corporate Directors website.
[61] Jens Opdenbusch, Jonas Hielscher, and M Angela Sasse. 2025. " Where Are We On Cyber?"-A Qualitative Study On Boards' Cybersecurity Risk Decision Making.. In *NDSS*.
[62] Peng Peng, Chao Xu, Luke Quinn, Hang Hu, Bimal Viswanath, and Gang Wang. 2019. What happens after you leak your password: Understanding credential sharing on phishing sites. In *Proceedings of the 2019 ACM Asia Conference on Computer and Communications Security (AsiaCCS)*. 181–192.
[63] Susanne Peters. 2021. Market conditions of international VET providers: A comparative analysis of Australia, UK, USA, and Germany. *Empirical Research in Vocational Education and Training* 13, 1 (2021), 23.
[64] Andrew Pettigrew and Terry McNulty. 1995. Power and influence in and around the boardroom. *Human Relations* 48, 8 (1995), 845–873.
[65] PricewaterhouseCoopers. 2024. Board Central. https://www.pwc.com/us/en/products/board-central.html. Accessed: 29/05/2024.
[66] Harvard Business Review. 2025. Boards Need a More Active Approach to Cybersecurity. https://hbr.org/2025/05/boards-need-a-more-active-approach-to-cybersecurity. Accessed: 2025-09-03.
[67] Amir Rubin and Dan Segal. 2019. Directors skill and financial reporting quality. *Journal of Business Finance & Accounting* 46, 3-4 (2019), 457–493.
[68] Susanne Barkhald Sandberg, Aida Akbarzadeh, and Vasileios Gkioulos. 2023. Effects of organizational cyber security culture across the energy sector supply chain. In *European Symposium on Research in Computer Security*. Springer, 5–24.
[69] Süleyman Savaş, Serkan & Karataş. 2022. Cyber governance studies in ensuring cybersecurity: an overview of cybersecurity governance. *International Cybersecurity Law Review* 3, 7–24.
[70] Stef Schinagl and Abbas Shahim. 2020. What do we know about information security governance? "From the basement to the boardroom": Towards digital security governance. *Information & Computer Security* 28, 2 (2020), 261–292.
[71] Justin Short, John D'Arcy, and Yili Hong. 2024. Chief Information Officers (CIOs) joining outside boards of directors: Impact on their home firms' cybersecurity. *Available at SSRN 4750083* (2024).
[72] Sergeja Slapničar, Tina Vuko, Marko Čular, and Matej Drašček. 2022. Effectiveness of cybersecurity audit. *International Journal of Accounting Information Systems* 44 (2022), 100548.
[73] Nadia Smaili, Camélia Radu, and Amir Khalili. 2023. Board effectiveness and cybersecurity disclosure. *Journal of Management and Governance* 27, 1049–1071.
[74] Telstra Corporation Limited. 2017. The Five Knows of Cyber Security. https://www.telstra.com.au/content/dam/tcom/business-enterprise/security-services/pdf/5-knows-of-cyber-security.pdf Accessed: 2025-12-02.
[75] Nadia Toumi, Ramzi Benkraiem, and Amal Hamrouni. 2016. Board director disciplinary and cognitive influence on corporate value creation. *Corporate Governance* 16, 3 (2016), 564–578.
[76] Betsy Uchendu, Jason RC Nurse, Maria Bada, and Steven Furnell. 2021. Developing a cyber security culture: Current practices and future needs. *Computers & Security* 109 (2021), 102387.
[77] Subhan Ullah, Sardar Ahmad, Saeed Akbar, Devendra Kodwani, and Jane Frecknall-Hughes. 2021. Governance disclosure quality and market valuation of firms in UK and Germany. *International Journal of Finance & Economics* 26, 4 (2021), 5031–5055.
[78] Leo Van Audenhove and Karen Donders. 2019. Talking to people III: Expert interviews and elite interviews. *The Palgrave handbook of methods for media policy research* (2019), 179–197.
[79] Sabine Vollmer. 2017. Building a more effective board. *Journal of Accountancy* 224, 2 (2017).
[80] Eleanor Watkins, Patrick Olivier, Shaun Stewart, Kaleb Johnstone, and James Nicholson. 2025. Understanding the Trade-offs Chief Information Security Officers Make in Practice. In *Proceedings of the CHI Conference on Human Factors in Computing Systems (CHI '25)*. ACM, New York, NY, USA, 1–16. doi:10.1145/3706598.3713220
[81] Andreas Witzl and Herwig Reiter. 2012. The problem-centred interview: Principles and practice.
[82] World Economic Forum. 2021. *Principles for board governance of cyber risk*. World Economic Forum. https://www.weforum.org/whitepapers/principles-for-board-governance-of-cyber-risk
[83] Tingmin Wu, Rongjunchen Zhang, Wanlun Ma, Sheng Wen, Xin Xia, Cecile Paris, Surya Nepal, and Yang Xiang. 2020. What risk? I don't understand. An empirical study on users' understanding of the terms used in security texts. In *Proceedings of the 15th ACM Asia Conference on Computer and Communications Security (AsiaCCS)*. 248–262.

A Appendix - Research Methods

A.1 Interview Protocol

Structure. Semi-structured, problem-centred interviews were conducted with directors and senior executives (45-60 minutes, two facilitators, online). The prompts below were compiled from the original interview protocol and supplemented with additional themes that emerged during the interviews, including issues raised by directors and insights arising from open-ended questions. Prompts were organised to follow the slide deck flow, with interviewers free to probe and reorder as appropriate.

A.1.1 Opening.

- Welcome and introduction; confirm role, sector, and board experience.
- How often does cybersecurity appear on the board agenda, and who leads the item?
- What kinds of board-level decisions typically arise when cyber is discussed?

A.1.2 Theme 1: Knowledge of Laws, Regulations, and Controls (RQ1). Goal: establish baseline literacy and obligations recognised by directors.

- Which cybersecurity laws, regulations, or frameworks are you most familiar with (e.g., Privacy Act, GDPR, APRA CPS 234, SOCI)?
- How do these obligations appear in board reporting or discussions?
- Where do you feel confident, and where do you see gaps?

A.1.3 Theme 2: Cyber Risks, Threats, and Strategy in Practice (RQ1/RQ2). Goal: understand how boards conceptualise and oversee cyber risk.

- What cyber risks are considered most material for your organisation?
- How are these risks managed or monitored (risk registers, KPIs, maturity models, external audits)?
- What content typically reaches the board pack? Which elements are useful versus noise?
- To what extent are cyber risks framed as business risks versus technical compliance?

A.1.4 Theme 3: Board Expertise, Information Quality, and Decision Cadence (RQ2). Goal: link capability, information, and cadence to decision quality.

- How does the board interact with the CISO or security lead (including in-camera)?
- Which metrics/KPIs do you find most decision-useful? Which are less helpful?
- How does independent challenge (internal audit, external consultants) influence board oversight?
- What role does director education or external briefings play in improving capability?

A.1.5 Theme 4: Incident Management and Governance (RQ3). Goal: describe board role during and after a cyber incident.

- At what point is the board informed during a significant incident? Who decides thresholds for escalation?
- How are board updates structured (time-boxing, designated spokesperson, regulatory timelines)?
- What role does the board play in disclosure and external communication?
- What follow-up occurs after an incident (after-action review, investments, policy change)?

A.1.6 Theme 5: Cyber Resilience and Forward-Looking Governance (RQ3/RQ4). Goal: assess how boards think about resilience and long-term preparedness.

- How is "resilience" understood at board level (continuity, recovery, stakeholder trust)?
- Which practices or tools help your board connect posture snapshots to business consequences?
- What would make the next 12 months of cyber oversight more effective for your board?

A.1.7 Closing.

- If you could change one thing about how cyber is governed at board level, what would it be?
- Is there anything we haven't asked that you think is critical?

Ethics note. Directors were asked to respond with one focal board in mind and avoid disclosing sensitive identifiers; redaction was encouraged when sharing artefacts.

A.2 Codebook (Top-Level Codes, Definitions, Example Quotes)

Codes were developed reflexively and iteratively, aligned to RQs; two analysts double-coded a calibration subset with reconciliation (See Table 5).
Note. Subcodes and example indicators are available on request (e.g., "Assurance-source type," "Board ask type," "Escalation trigger type").

A.3 Audit Trail and Analysis Memos

Data management. All interviews were audio- or video-recorded with participant consent, and the recordings were transcribed and then anonymised to remove identifying details. Anonymised transcripts were stored on access-controlled institutional drives with restricted researcher access. We maintained a secure file inventory that logged interview IDs, dates, consent confirmations, and the location of corresponding materials to support traceability and auditability.

Codebook evolution (extract).

- v0.1 (early calibration): seed codes from RQs (board-pack, decision framing, information quality, cadence, challenge, incident roles, communications, learning).
- v0.2: split "compliance vs. resilience" from decision framing; added "third-party risk" as cross-cutting.
- v0.3: merged overlapping KPI subcodes; added "escalation thresholds" and "materiality logic" under incident roles.

Double-coding slice. Two analysts coded three transcripts; the calibration subset was selected to reflect variation in organisational size and sector (e.g., one regulated, one non-regulated entity). Cohen's κ was computed on overlapping segments for calibration; disagreements were reconciled through comparison of interpretive rationales, clarification of code boundaries, and examination of alternative segmentations until a shared interpretation was reached. The remaining transcripts were coded against v0.3.

Memo excerpts (illustrative):

- **M-07 (Info quality vs. maturity):** Board leans on maturity heatmap for comparability; CISO attempts to add restore-to-RTO and vendor concentration. Tension: directors find heatmaps legible but not actionable. The decision is unclear. "Maturity scores can be gamed; directors really want consequence-forward measures like mean-time-to-detect or restore-to-service."(P006)
- **M-11 (Incident thresholds):** Early notification valued, but thresholds not pre-agreed; public comms delayed while "materiality" debated. After-action review noted but no investment follow-up recorded. "Data-related incidents now trigger urgent

Table 5: Top-level codes with definitions and exemplar quotes

Code	Definition / Indicators	Exemplar quote (ID)
Board-pack content (RQ1)	Items reaching board: posture snapshot, crown jewels, third-party exposure, incident trendlines, compliance/exception logs, assurance notes; what directors read vs. skim.	*"Our packs are full of traffic-light dashboards, but without context they don't tell us what decisions to make."* (P009)
Decision framing (RQ1)	Risk appetite/tolerances, trade-offs (availability vs. confidentiality), options and asks; pairing of maturity scores with outcome KPIs.	"*We can read the traffic lights, but we need to understand what they mean for the business next quarter."* (P009)
Compliance vs. resilience (RQ1)	Reliance on compliance artefacts vs. readiness/recoverability; assurance for stakeholders vs. risk reduction.	*"More compliance does not equal less risk . . . it becomes a tick-boxing exercise for assurance rather than real reduction."* (P004)
Information quality (RQ2)	Consequence-forward KPIs (MTTD/MTTR, restore-to-RTO, backup integrity, third-party coverage); plain-language narratives; thresholds.	*"Maturity scores can be gamed; directors really want consequence-forward measures like mean-time-to-detect or time-to-restore."* (P006)
Cadence & access (RQ2)	Quarterly cyber item; in-camera CISO session; ad hoc briefings for incidents/regulatory change.	*"Boards must change their understanding of risks and see cyber as a living process, not a one-off register."* (P002)
Independent challenge (RQ2)	Internal audit; external testing/red team; director calibration of management narrative; follow-up to closure.	*"External reviews help us test whether management's view is too optimistic or whether we're actually prepared."* (P008)
Director capability (RQ2)	Presence of cyber/tech-savvy director; constructive challenge culture; basic literacy expectations.	*"Board members don't need to be cybersecurity experts, but they should have a basic understanding of the key risks and strategies to mitigate them."* (P004)
Incident thresholds & roles (RQ3)	When the board is informed; who decides what; escalation triggers; materiality/disclosure logic.	*"Data-related incidents now trigger urgent board action—system availability is as critical as confidentiality."* (P007)
Communication discipline (RQ3)	Scripted updates; time-boxed briefings; single spokesperson; regulator/stakeholder coordination.	*"Rushing to provide information can backfire; you need accuracy and timeliness, even if that means saying less in the first hour."* (P010)
Learning loops (RQ3)	After-action reviews; returning lessons to the board; linking to policy/investment.	*"We always close with an after-action review—otherwise the same mistakes keep repeating."* (P005)
Third-party risk (cross-cutting)	Concentration mapping; due diligence; contract clauses (notification, right to audit); vendor incident handling.	*"Third-party security is a nightmare—our risk exposure depends on suppliers we can't fully control."* (P006)

board action—system availability is as critical as confidentiality."(P007)

- **M-14 (Reflexive assumption check):** Expected directors to emphasise regulatory compliance; several instead foregrounded resilience, cadence, and operational trade-offs. Marked the need to avoid over-weighting regulatory narratives during coding.

Saturation signals. Recurrent patterns stabilised by interview 10 for board-pack content, use of assurance, and incident role clarity; later interviews added nuance (e.g., in-camera cadence) but few novel codes.